

Degree Project in Computer Science and Engineering and Industrial Management

Second cycle, 30 credits

Deploying LLMs for Enterprise Analytics on Sensitive Data

A Socio-Technical Comparison of Contractual and Architectural Data Control

LEON FÄLLMAN

Deploying LLMs for Enterprise Analytics on Sensitive Data

A Socio-Technical Comparison of Contractual and Architectural Data Control

by

Leon Fällman

Master of Science Thesis TRITA-ITM-EX 2026:447
KTH Industrial Engineering and Management
Industrial Economics and Management
SE-100 44 STOCKHOLM

Driftsättning av LLM:er för företagsanalys på känslig data

En socioteknisk jämförelse av kontraktuell och arkitekturell datakontroll

Leon Fällman

Examensarbete TRITA-ITM-EX 2026:447
KTH Industriell teknik och management
Industriell ekonomi och organisation
SE-100 44 STOCKHOLM

Master of Science Thesis TRITA-ITM-EX 2026:447

Deploying LLMs for Enterprise Analytics on Sensitive Data

A Socio-Technical Comparison of Contractual and Architectural Data Control

Leon Fällman

Industrial economics and management

Approved	Examiner	Supervisor
2026-06-16	Johan Nordensvärd	Magnus Rattfeldt

Abstract

Organizations adopting Large Language Models for analytics on sensitive data face a choice between two forms of data control. Cloud API services such as Azure OpenAI provide access to proprietary models under data processing agreements and contractual no-training guarantees, but inference-time data is processed by infrastructure operated by the cloud platform under those contractual commitments. Alternatively, organizations can deploy open-weight models within their own cloud tenancy, where prompt content is not transmitted to a separate managed LLM API provider and the model-serving stack runs within infrastructure the organization administers, at the cost of greater operational complexity.

This thesis frames the deployment choice as a socio-technical problem, structured around the distinction between contractual and architectural data control. The study employs a mixed-methods design combining technical benchmarking of natural language to SQL accuracy and latency, semi-structured interviews with thirteen practitioners, and governance analysis, interpreted through the Technology-Organisation-Environment (TOE) framework.

In a synthetic NL2SQL benchmark, the self-hosted open-weight model (Qwen3-235B in INT4 quantization) achieved higher observed execution accuracy than the proprietary cloud API model (GPT-5.1 via Azure OpenAI Service), with 22% versus 14% overall. However, both models performed poorly on complex and ambiguous queries and failed all queries involving sensitive columns. The results therefore suggest that self-hosted deployment does not necessarily impose an observed accuracy penalty under the tested conditions, but also indicate that neither architecture is sufficient for unsupervised enterprise analytics without validation and governance controls. The interview findings reveal that the deployment decision operates as a governance threshold function moderated by the organizational salience of regulation, the degree to which regulatory requirements are embedded in daily technology decision-making. Organizations where regulation was operationally salient required self-hosted deployment; organizations in regulated industries without operational enforcement accepted managed services with contractual protections; and organizations under standard baseline regulation without operational salience defaulted to managed cloud services driven by cost and capability. The thesis contributes an extension of the TOE framework from binary adoption to deployment mode selection, the conceptual vocabulary of contractual versus architectural data control, and practical decision guidance for organizations navigating this choice.

Key-words

Large Language Models, Enterprise Analytics, Deployment Models, Data Governance, TOE Framework, Regulatory Salience, Open-Weight Models

Examensarbete TRITA-ITM-EX 2026:447

Driftsättning av LLM:er för företagsanalys på känslig data

En socioteknisk jämförelse av kontraktuell och arkitekturell datakontroll

Leon Fällman

Industriell ekonomi
och organisation

Godkänt	Examinator	Handledare
2026-06-16	Johan Nordensvärd	Magnus Rattfeldt

Sammanfattning

Organisationer som vill använda stora språkmodeller för analys av känslig data ställs inför ett val mellan två former av datakontroll. Molnbaserade API-tjänster som Azure OpenAI Service ger tillgång till proprietära modeller under databehandlingsavtal och kontraktuella skyddsåtgärder, men inferensdata behandlas av infrastruktur som drivs av plattformsoperatören enligt dessa kontraktuella villkor. Alternativt kan organisationer driftsätta open-weight-modeller i organisationens egen molntenancy, där promptinnehåll inte överförs till en separat hanterad LLM-API-leverantör och modellservering körs inom infrastruktur som organisationen administrerar, till priset av högre operativ komplexitet.

Denna uppsats formulerar driftsättningsvalet som ett sociotekniskt problem, strukturerat kring skillnaden mellan kontraktuell och arkitekturell datakontroll. Studien använder en blandad metoddesign som kombinerar teknisk benchmarking av träffsäkerhet och latens vid naturligt språk till SQL-översättning, semistrukturerade intervjuer med tretton yrkesverksamma, samt en styrningsanalys, tolkad genom Technology-Organisation-Environment-ramverket (TOE).

Benchmarkresultaten visar att den självdriftsatta open-weight-modellen (Qwen3-235B i INT4-kvantisering) uppnådde högre observerad träffsäkerhet än den proprietära molntjänsten (GPT-5.1 via Azure OpenAI Service), 22 % mot 14 %. Båda modellerna presterade dock dåligt på komplexa och tvetydiga frågor och ingen modell besvarade frågor som rörde känsliga kolumner korrekt. Resultaten antyder att självdriftsättning inte nödvändigtvis innebär en observerad träffsäkerhetsförlust under de testade förutsättningarna, men visar också att ingen av arkitekturerna är tillräcklig för oövervakad företagsanalys utan validering och styrningskontroller. Intervjuerna visar att driftsättningsbeslutet fungerar som en styrningströskel modererad av den organisatoriska förankringen av regulatoriska krav (regulatory salience): hur djupt regulatoriska krav är inbäddade i den dagliga teknikbeslutsprocessen. Organisationer där reglering var operativt förankrad krävde självdriftsättning; organisationer i reglerade branscher utan operativ förankring accepterade hanterade molntjänster med kontraktuella skyddsåtgärder; och organisationer under standardreglering utan operativ förankring valde molntjänster av kostnads- och kapacitetsskäl. Uppsatsen bidrar med en utvidgning av TOE-ramverket från binära adoptionsbeslut till val av driftsättningsmodell, det begreppsliga ramverket kontraktuell kontra arkitekturell datakontroll, samt praktisk beslutsvägledning för organisationer.

Nyckelord

Stora språkmodeller, Företagsanalys, Driftsättningsmodeller, Datagovernance, TOE-ramverket, Regulatorisk förankring, Open-weight-modeller

© 2026 Leon Fällman

Acknowledgments

This thesis would not have been possible without the practitioners who agreed to share their reasoning about a deployment decision that few organizations are entirely comfortable discussing on the record. They are anonymized in the body of the thesis, but their willingness to engage thoughtfully with questions about governance, capability, and risk is what made the empirical contribution possible. I am grateful to each of them.

I would like to thank my supervisor at KTH for guidance on framing a topic that sits awkwardly between computer science and industrial management, and for steady pressure to make claims only as strong as the evidence permits. I am also grateful to my examiner for sharp questions at the seminar stage that pushed the analysis toward the calibrated form it now takes.

The peer reviewer who read an earlier draft caught several substantive errors that this version corrects. The clarity of the final argument owes a great deal to that review.

Finally, to friends and family in Stockholm and elsewhere who tolerated long stretches of distracted attention during the writing of this thesis: thank you.

Stockholm, June 2026
Leon Fällman

Contents

List of Acronyms and Abbreviations xi

1 Introduction **1**
1.1 Motivation 1
1.2 Problem Statement 3
1.3 Research Question 4
1.4 Scope and Delimitations 5

2 Background **7**
2.1 Large Language Models for Enterprise Analytics 7
2.1.1 The Open-Source Model Landscape 8
2.2 The TOE Framework and the Deployment Decision 9
2.2.1 Prior Applications to Cloud and AI Adoption 9
2.2.2 The Adoption-Deployment Gap 10
2.3 Data Governance and the Regulatory Landscape 10
2.3.1 The GDPR Framework for AI Processing 11
2.3.2 The EU AI Act 12
2.4 Contractual Versus Architectural Data Control 13
2.5 What “Open Source” Means for Deployment 14
2.6 Privacy Risks in LLM Processing 15
2.7 Summary and Research Gap 16

3 Methodology **21**
3.1 Research Design 21
3.1.1 Research Philosophy 21
3.1.2 Abductive Reasoning 22
3.1.3 Literature Approach 22
3.1.4 Theoretical Lens: The TOE Framework 23
3.1.5 Mixed-Methods Design 23
3.1.6 Strengths and Limitations of the Mixed-Methods Design 25

3.2 Technical Benchmarking 26
3.2.1 Models and Deployment Configurations 27
3.2.2 Task Design 28
3.2.3 Evaluation Metrics 31
3.2.4 Cost Estimation 31
3.3 Organizational Interviews 32
3.3.1 Sample and Recruitment 32
3.3.2 Interview Design 33
3.3.3 Thematic Analysis 34
3.4 Governance and Compliance Analysis 37
3.5 Ethical Considerations 38
3.5.1 Use of AI Assistants in the Preparation of the Thesis . 38

4 Findings **41**
4.1 Technical Benchmarking 41
4.1.1 Accuracy 41
4.1.2 Error Analysis 42
4.1.3 Latency 43
4.1.4 Cost Structure 43
4.1.5 Summary of Benchmarking Findings 46
4.2 Interview Findings 47
4.2.1 Technological Context: Capability Is Assumed, Not Evaluated 47
4.2.2 Organizational Context: Capability and Cost as Gatekeepers 49
4.2.3 Environmental Context: Regulation as the Decisive Factor 51
4.2.4 The Deployment Decision: A Governance Threshold . 52
4.3 Governance Comparison 54
4.3.1 Data Residency and International Transfer 54
4.3.2 Data Processing Agreements and Subprocessor Chains 55
4.3.3 Auditability and Logging 55
4.3.4 Data Lifecycle Control 56
4.3.5 Contractual Versus Architectural Guarantees 56

5 Discussion **59**
5.1 Integrating Findings Through the TOE Framework 59
5.1.1 Technological Context: Architecture Is Not the Differentiator 60

5.1.2 Organizational Context: Capability as Enabler, Not Determinant . . . 61
5.1.3 Environmental Context: Regulatory Salience as the Threshold . . . 62
5.2 Contractual Versus Architectural Control . . . 65
5.3 The Meaning of "Open Source" for Deployment Decisions . . . 66
5.4 Implications for Industrial Management Practice . . . 67
5.4.1 Make-or-buy and vendor dependence . . . 67
5.4.2 Capability building as governance investment . . . 68
5.4.3 Governance operating model and procurement gates . . . 68
5.4.4 Decision guidance by organizational profile . . . 69
5.5 Limitations . . . 70
5.5.1 Synthetic Benchmark Schema . . . 70
5.5.2 Temporal Scope of Benchmarking . . . 70
5.5.3 Interview Sample Composition . . . 70
5.5.4 Interview Format . . . 71
5.5.5 Single Model Per Architecture . . . 71
5.5.6 Single-Researcher Coding . . . 71
5.5.7 European Regulatory Focus . . . 72
5.5.8 Sustainability Trade-off Not Quantified . . . 72

6 Conclusions **73**
6.1 Summary of Findings . . . 73
6.2 Contributions . . . 74
6.3 Future Research . . . 75

References **77**

A Interview Protocol **85**

B Benchmark Materials **89**

List of Figures

2.1 Cloud API versus self-hosted deployment topologies. In (a), prompt content crosses the organization perimeter to a managed LLM service, and data protection rests on contractual instruments. In (b), prompt content stays within the organization's cloud tenancy at the LLM layer; the cloud infrastructure provider operates the underlying compute but does not access prompt content, and the LLM-layer data protection is architectural rather than contractual. 19

4.1 Per-query cost as a function of daily query volume, log-log scale. The cloud API cost is independent of volume; the self-hosted cost (24/7 GPU operation) declines with utilisation. The two curves meet at approximately 43,800 queries per day. At realistic enterprise analytics volumes (hundreds to a few thousand queries per day), the self-hosted configuration costs one to two orders of magnitude more per query than the cloud API. 46

5.1 Governance threshold model. Participant identifiers (P1–P13) refer to the interview sample profiled in Table 4.5. The deployment decision is moderated by regulatory salience (the operational internalization of regulatory requirements) rather than by the existence of regulation alone. Strictly regulated organizations whose compliance functions are embedded in AI procurement (above threshold) require architectural control; strictly regulated organizations whose compliance is formal but not operationally enforced (gray zone) accept contractual control; organizations under baseline regulation without operational salience default to managed services driven by cost and capability. 64

List of Tables

3.1 Representative benchmark queries, one per difficulty level. *Sens.* indicates whether the gold SQL touches a column annotated as sensitive (customer names, `personnummer`, `salary_sek`, contact details). Long SQL has been line-wrapped for display. 30
3.2 Example interview questions from each TOE context. The full protocol is reproduced in Appendix A. 34

4.1 Execution accuracy by query difficulty level. 41
4.2 Error distribution across 250 executions per model. 42
4.3 Response latency in milliseconds. 43
4.4 Per-query cost comparison under continuous self-hosted GPU operation. 45
4.5 Interview participant profiles. Sensitivity, regulation, capability and observed regulatory salience were coded from interview accounts using the scheme described in Section 3.3.3. "Regulation" reflects formal legal and sector-specific exposure; "salience" reflects whether regulatory requirements were built into the participant's account of technology decision-making. Preferred deployment reflects the participant's stated or implied preference at the time of the interview. 48

4.6 Theme-to-participant matrix. A bullet (•) indicates that the participant's interview account contained at least one coded segment supporting the theme. The four themes are: **T1** Capability is assumed, not evaluated; **T2** Capability and cost as gatekeepers; **T3** Regulation as the decisive factor; **T4** The deployment decision as a governance threshold. Themes T1 and T3 differentiate among participants; T2 and T4 are framework-level themes that organize all thirteen accounts (every account contains some statement about capability or cost gatekeeping, and every account positions the organization somewhere on the governance threshold). 49
4.7 Governance comparison across deployment architectures. . . . 56

Listings

List of Acronyms and Abbreviations

AI Act	Artificial Intelligence Act (Regulation (EU) 2024/1689)
API	Application Programming Interface
AWQ	Activation-aware Weight Quantization
CLOUD Act	Clarifying Lawful Overseas Use of Data Act (United States, 2018)
CNIL	Commission Nationale de l'Informatique et des Libertés
CTE	Common Table Expression (SQL)
DPA	Data Processing Agreement (GDPR Article 28)
DPF	EU–US Data Privacy Framework
DPIA	Data Protection Impact Assessment (GDPR Article 35)
DPO	Data Protection Officer
EDPB	European Data Protection Board
EU	European Union
FP16	16-bit floating-point (half precision)
GDPR	General Data Protection Regulation (Regulation (EU) 2016/679)
GPU	Graphics Processing Unit
HIPAA	Health Insurance Portability and Accountability Act (United States)
INT4	4-bit integer quantization
KV cache	Key–Value cache used by transformer attention
LLM	Large Language Model
MLOps	Machine Learning Operations
MoE	Mixture-of-Experts
NL2SQL	Natural Language to SQL
PIPL	Personal Information Protection Law (China)
SLA	Service-Level Agreement
SOC 2	Service Organization Control 2 (AICPA Trust Services audit)
SQL	Structured Query Language
TOE	Technology–Organisation–Environment (framework)
vLLM	open-source library for high-throughput LLM inference serving
W4A16	4-bit weights, 16-bit activations (a quantization scheme)

Chapter 1

Introduction

This chapter opens the thesis by setting out why the deployment decision between cloud API and self-hosted open-weight LLMs is consequential for organizations handling sensitive data, and by framing it as a problem worth investigating from an industrial-management perspective. It begins with the motivation behind the study (Section 1.1), articulates the specific problem the thesis addresses (Section 1.2), states the research question and the methodological strategy used to investigate it (Section 1.3), and closes with the scope and delimitations of the work (Section 1.4). The detailed positioning against prior literature follows in Chapter 2.

1.1 Motivation

Organizations that want to use Large Language Models for analytics on sensitive data face a deployment decision with significant governance implications. They can access proprietary models through a cloud API, relying on contractual mechanisms such as data processing agreements, no-training guarantees, and regional hosting options to protect their data. Or they can deploy open-weight models within their own cloud infrastructure, where prompt content is not transmitted to a separate managed LLM API provider and data protection rests primarily on architectural rather than contractual mechanisms. Both approaches are technically viable, and recent open-weight models have closed much of the capability gap with proprietary alternatives on structured analytics tasks [1, 2]. If the models are roughly comparable, the deployment decision is not primarily about capability. It is about governance.

The choice has a long intellectual lineage in industrial management. Williamson's transaction-cost framing of contractual versus internal gov-

ernance [3] and the IT-outsourcing literature that operationalized it for information systems [4] treat the buy-versus-build question as a function of asset specificity, uncertainty, and the costs of monitoring contractual performance. Schneider and Sunyaev [5] explicitly extend this lineage to cloud sourcing, showing that most determinants of traditional IT outsourcing carry over to cloud-service procurement, but that the peculiarities of cloud, including shifting task responsibilities and short-term standardized contracts, require re-examination of received concepts. The choice to build internal capability rather than procure it externally is in turn a dynamic-capabilities decision [6]: it commits the organization to a path of skill accumulation and asset configuration that is difficult to reverse once embarked upon. LLM deployment for sensitive analytics combines all of these dimensions in a single decision, and existing applications of the TOE framework to generative AI adoption [7] or to deployment-mode choice in generic cloud computing [8] address parts of the problem but not the integrated case.

The decision matters now, and not in a few years. European organizations operate under a tightening regulatory regime that combines the GDPR [9] with the EU AI Act [10], and the architectural choices made early in an LLM rollout are difficult to reverse: data processing agreements are negotiated, vendor relationships are entered, internal MLOps capability is either built or foregone, and tooling and training accumulate around whichever path was chosen first. Practitioners are making these decisions today, often without integrated guidance: technical benchmarks compare model accuracy without addressing governance [11, 12], governance frameworks recommend "keeping data on-premise" without evaluating whether open-source models are performant enough to justify the operational investment, and organizational adoption studies [7] identify factors that drive AI uptake without distinguishing between deployment modes. The closest existing comparative study is confined to a single domain [2], and the contested meaning of "open source" itself complicates any claim that self-hosted deployment automatically delivers transparency or control [13].

This thesis treats the choice between cloud API and self-hosted open-weight LLM deployment as a structured industrial-management problem: a make-or-buy decision over inference infrastructure [3, 4], a vendor-dependence and concentration question [5], a capability-building decision about whether to develop internal MLOps practice [6], and a risk-governance question about acceptable exposure to third-country jurisdictions under post-Schrems II EU data protection law [14, 15]. Each of these is a familiar object of study in industrial management research, but their interaction

in the specific case of LLM deployment for analytics on sensitive data is not well understood. The work therefore sits at the intersection of three disciplines: industrial engineering and management, which supplies the sourcing, capability, and governance constructs; computer science, which supplies the model architectures, serving infrastructure, and NL2SQL evaluation methods that determine whether self-hosted deployment is technically viable; and information and data protection law, which determines the boundary conditions under which contractual data protection is sufficient and architectural control becomes necessary. The detailed positioning against the relevant academic literature, and the precise gap this thesis addresses, is developed at the end of the literature review in Section 2.7.

1.2 Problem Statement

When an organization deploys a Large Language Model for analytics on sensitive data, the nature of data control differs in important ways between the two dominant deployment architectures. In a cloud API deployment, the organization sends queries containing schema information, data samples and natural language questions to an external endpoint operated by a managed service provider. In the case of Azure OpenAI Service, for example, Microsoft's documentation states that prompts and completions are not made available to the upstream model provider (OpenAI) and are not used for model training without the customer's explicit consent. The data protection therefore rests on contractual commitments (data processing agreements, no-training clauses, and service-level agreements) between the organization and the cloud platform operator, and the controls over inference-time data are contractual rather than architectural. In a self-hosted deployment, the organization runs an open-weight model within its own cloud tenancy on GPU instances it controls. Prompt content is not transmitted to a separate managed LLM API provider, and the model-serving stack runs entirely within infrastructure the organization administers. The cloud infrastructure provider remains part of the processing environment as the operator of the underlying compute, but is governed by a standard infrastructure DPA. The data protection therefore rests primarily on the deployment topology itself: it is architectural rather than contractual with respect to the LLM-specific layer of the stack.

This distinction between contractual and architectural data control is consequential for organizations operating under regulatory frameworks such as the GDPR. Contractual control depends on trust in the provider's compliance, enforcement mechanisms, and the legal enforceability of

processing agreements across jurisdictions. Architectural control reduces the data transfer to an LLM-specific provider and shifts the protection of inference-time data into the organization's deployment topology, but it does not eliminate the cloud infrastructure provider from the processing environment, and it introduces operational requirements: GPU infrastructure, model serving software, engineering expertise, and ongoing maintenance.

The decision between these architectures is therefore not purely technical. It is a structured industrial-management problem that combines a make-or-buy choice over inference infrastructure [3, 4], vendor-dependence and concentration management [5], capability-building decisions about whether to develop internal MLOps practice [6], and risk governance about acceptable exposure to third-country jurisdictions [14]. Each of these is a familiar object of study in industrial management research, but their interaction in the specific case of LLM deployment for analytics on sensitive data is what this thesis examines.

In practice, organizations making this decision lack integrated guidance. Technical benchmarks compare model accuracy but do not address governance implications. Governance frameworks recommend "keeping data on-premise" without evaluating whether the available open-source models are performant enough to justify the operational investment. Organizational adoption studies identify factors that drive AI uptake but do not differentiate between deployment modes. The result is that practitioners must assemble evidence from disconnected sources and make consequential deployment decisions under uncertainty.

1.3 Research Question

This thesis addresses the following research question:

> *How do governance and data control requirements influence the organizational choice between cloud API and self-hosted open-weight LLM deployment for analytics on sensitive data?*

The question is deliberately scoped to the governance and data control dimension of the deployment decision. Technical performance is treated as a precondition rather than the primary object of inquiry. The thesis tests through a scoped NL2SQL benchmark whether the two deployment models are technically comparable for structured analytics tasks, finds no observed accuracy disadvantage for the self-hosted model under the tested

conditions, and then investigates the governance and organizational factors that shape the choice between them. The analysis is structured around the Technology-Organisation-Environment (TOE) framework [16], extended from its traditional use in binary adoption studies to the deployment mode decision. This framing reflects the empirical observation, consistent across prior literature and preliminary industry conversations, that organizations rarely reject a deployment model on technical grounds alone. The decisive factors are governance requirements, data control preferences, regulatory obligations, and organizational capability, all of which map onto the three TOE contexts.

The question is investigated through a mixed-methods design combining three components. First, technical benchmarking compares the accuracy and latency of a proprietary cloud API model and a self-hosted open-weight model on enterprise NL2SQL tasks, examining whether deployment architecture is a dominant performance factor. Second, semi-structured interviews with practitioners who have made or influenced LLM deployment decisions in organizations handling sensitive data provide qualitative evidence on the governance and organizational factors that drive the choice. Third, an analysis maps how each deployment architecture addresses data control, regulatory compliance, and residual risk.

1.4 Scope and Delimitations

This thesis examines the deployment of Large Language Models for enterprise analytics workflows involving natural language to SQL translation and related data interaction tasks. The data context is sensitive organizational information subject to regulatory protection under GDPR. The two deployment models compared are cloud APIs serving proprietary models (specifically GPT-5.1 via Azure OpenAI Service) and cloud-deployed open-weight models running in the organization's own cloud tenancy (specifically Qwen3-235B-A22B in INT4 quantization served via vLLM on two NVIDIA A100 80GB GPUs). On-premise bare-metal deployment is discussed qualitatively but is not benchmarked.

The primary analytical lens is the TOE framework, applied to the governance and data control dimension of the deployment decision. Technical benchmarking tests for performance parity on a scoped NL2SQL workload and is treated as supporting evidence, not as the main contribution. Cost modeling is discussed where it intersects with governance decisions (e.g., the cost of achieving architectural control) but a comprehensive total-cost-of-ownership

analysis is outside scope. The interview component is exploratory, involving a small number of practitioners, and identifies patterns rather than statistically generalizable claims.

The following delimitations apply:

- The benchmarks use a synthetic database schema rather than real confidential datasets from a production environment. The schema is designed to approximate enterprise data warehouse structures, but it does not reproduce characteristics such as naming ambiguity, undocumented relationships, or domain jargon that are typical of legacy production schemas. Results therefore reflect relative performance differences between deployment architectures rather than the absolute accuracy either would achieve in a specific organization.
- The evaluation assumes pre-trained models used via prompting; fine-tuning and retrieval-augmented generation are outside scope.
- The governance analysis examines architectural data control differences, not comprehensive security hardening or penetration testing.
- The research is conducted in a European regulatory context with the GDPR as baseline; findings may not transfer directly to other jurisdictions.
- The interview sample is purposive and exploratory; findings identify themes and patterns rather than statistically representative claims.

Chapter 2

Background

This chapter provides the conceptual and empirical foundations for the thesis. It begins with the technical capabilities that make the deployment decision possible, then introduces the theoretical framework that structures the analysis, before turning to the regulatory landscape and data governance considerations that constrain the decision. The chapter concludes by locating the research gap that this thesis addresses.

2.1 Large Language Models for Enterprise Analytics

Large language models are a class of neural networks based on the transformer architecture introduced by Vaswani et al. [17]. What distinguishes these models from earlier approaches to natural language processing is their ability to generalize across tasks without being explicitly trained for each one. Brown et al. [18] demonstrated this with GPT-3, showing that a model with 175 billion parameters could perform translation, summarization, question answering, and code generation simply by being given a few examples in the prompt, without any task-specific training. Bommasani et al. [19] formalized this idea under the term "foundation models," arguing that a single model trained on broad data can serve as the starting point for many downstream applications.

For enterprise analytics, the most relevant capability is natural language to SQL translation. This task requires the model to take a question posed in ordinary language, interpret it against a database schema, and generate a valid SQL query that retrieves the correct answer. The field has advanced through a series of benchmarks. Yu et al. [11] created Spider, which became the standard

by requiring cross-domain generalization across complex schemas with joins, nested queries, and aggregations. Li et al. [12] introduced BIRD to address Spider's limitations, incorporating real database values, larger schemas, and questions that require external domain knowledge.

However, a persistent gap separates benchmark performance from enterprise reality. Floratou et al. [20] examined this directly, finding that enterprise database schemas routinely contain thousands of columns and complex relationships that far exceed benchmark conditions. Their conclusion, that natural language to SQL "is a solved problem... not," reflects the fact that the best models achieve above 90% accuracy on Spider but only around 21% on enterprise schemas [21]. This gap matters for the deployment decision because it means organizations cannot simply assume that strong benchmark results will translate to reliable performance on their own data.

2.1.1 The Open-Source Model Landscape

The availability of capable open-source models is what makes the deployment choice possible in the first place. If only proprietary models could perform enterprise analytics tasks, there would be no decision to make. The open-source ecosystem has evolved rapidly. Touvron et al. [22] released LLaMA, demonstrating that models with 7 to 70 billion parameters could approach proprietary model performance. Subsequent releases have raised the bar further: Llama 3 [23] expanded the family to models exceeding 400 billion parameters, Qwen 2.5 [24] introduced strong multilingual capabilities, and mixture-of-experts architectures like Mixtral [25] showed that routing among specialized subnetworks allows models to achieve quality comparable to much larger dense architectures at a fraction of the computational cost during inference.

For enterprise deployment, a parallel development has been equally important: the maturation of inference serving infrastructure. Kwon et al. [26] introduced PagedAttention, a memory management technique that made it practical to serve large models on a small number of GPUs. The vLLM system built on this technique has become the standard inference engine for open-source model deployment. Two years ago, serving a 70 billion parameter model at production quality required significant custom engineering. Today, a well-configured vLLM deployment on two or four GPUs can deliver latencies and throughputs acceptable for interactive analytics.

Von Schwerin and Reichert [1] demonstrated in their systematic comparison of open and closed source models that open-source models, particularly

Qwen2-7B, achieved performance comparable to GPT-4 on GDPR compliance documentation tasks. They described open-source models as "cost-effective and privacy-preserving alternatives." Their findings confirm that the deployment decision is no longer primarily about whether open-source models are capable enough. The question has shifted to whether the organizational and governance conditions exist to deploy them effectively.

2.2 The TOE Framework and the Deployment Decision

The Technology-Organisation-Environment (TOE) framework, introduced by Tornatzky and Fleischer [16], provides the theoretical backbone for this thesis. The framework identifies three contexts that influence technology adoption decisions: the technological context (characteristics of the technology itself, such as relative advantage, complexity, and compatibility), the organizational context (internal factors such as firm size, management support, IT capability, and readiness for change), and the environmental context (external pressures including regulation, competition, and industry norms). It is one of the most widely used theoretical lenses for studying technology adoption in organizations, and its three contexts provide a natural structure for analyzing the deployment decision at the center of this thesis.

2.2.1 Prior Applications to Cloud and AI Adoption

The TOE framework has been applied extensively to cloud computing adoption. Oliveira et al. [27] used TOE to study cloud adoption among manufacturing and service firms, finding that technology readiness and competitive pressure were the strongest predictors. Lian et al. [8] applied it to cloud deployment model choice in Taiwanese hospitals, finding that business concern, specifically data security and control, was the most important factor in choosing between private and public cloud. This is the single closest precedent to the present thesis, as it studies the choice between deployment models rather than the binary adoption decision.

More recently, the framework has been applied to generative AI. Hughes et al. [7] surveyed 304 decision-makers globally and found that organizational change capacity is a critical moderator: the perceived complexity of generative AI becomes a barrier to adoption only when the organization lacks the capacity to manage change, and staff skills translate into adoption only when change

capacity is high. Agrawal [28] extended the TOE framework with institutional theory, arguing that organizations adopt AI not only because of its technical merits or internal readiness, but also due to coercive pressure from regulators, mimetic pressure from competitors, and normative pressure from professional communities.

2.2.2 The Adoption-Deployment Gap

A consistent limitation across this literature is that adoption is treated as a binary variable: organizations either adopt generative AI or they do not. The question of *which deployment model* an organization chooses, and what drives that choice, is not addressed. Hughes et al. [7] explicitly focus on whether organizations adopt generative AI, not on how they deploy it. Lian et al. [8] study deployment model choice, but in the context of generic cloud services, not AI-specific systems where the governance implications of the deployment decision are particularly acute.

This gap matters because the deployment decision is where governance requirements become operative. An organization may decide to adopt LLM-based analytics, but the governance implications differ enormously depending on whether the queries are processed by a third-party provider or within the organization's own infrastructure. The TOE framework is well suited to studying this choice. The technological context encompasses model capability and infrastructure requirements. The organizational context encompasses MLOps maturity, staffing, and governance readiness. The environmental context encompasses regulatory obligations, data sensitivity, and competitive dynamics. But no published study has applied the framework to this specific question. This thesis extends the TOE framework from adoption to deployment mode selection, using the three TOE contexts to structure both the empirical investigation and the analysis of findings.

2.3 Data Governance and the Regulatory Landscape

The regulatory environment constitutes the environmental context within the TOE framework that this thesis identifies as the decisive factor in the deployment decision. This section reviews the specific regulatory provisions that shape how organizations reason about LLM deployment for sensitive data.

Because "sensitive data" is used throughout this thesis as an umbrella term,

it is worth separating the categories it covers, since they carry different risk profiles and legal consequences. The first category is personal data in the GDPR sense: any information relating to an identified or identifiable natural person, with heightened obligations for the special categories enumerated in Article 9, such as health data [9]. The second is business-confidential data, including financial figures, source code, and trade secrets, which falls outside the GDPR but whose disclosure carries commercial and contractual consequences, as the Samsung incident discussed in Section 2.4 illustrates. A further distinction cuts across both categories: the difference between data *values* (the contents of a salary field or a customer record) and data *structure* (schema metadata such as table and column names). A prompt that contains only schema identifiers reveals what an organization stores, which may itself be commercially informative, but it is categorically less exposing than a prompt or response that contains the stored values. The deployment architectures compared in this thesis differ in where both kinds of content flow during inference, and the benchmark design in Chapter 3 states precisely which of them crosses the model boundary.

2.3.1 The GDPR Framework for AI Processing

The General Data Protection Regulation [9] imposes obligations on organizations that process personal data, and these obligations interact directly with the choice of LLM deployment architecture. Several provisions are particularly relevant. Article 28 requires a data processing agreement with any third party that processes personal data on behalf of the controller, making such agreements mandatory when using cloud LLM APIs. Article 32 requires "appropriate technical and organizational measures" to ensure data security. Article 25 establishes the principle of "data protection by design and by default," which reflects the understanding that architectural choices in system design can provide stronger privacy guarantees than contractual or procedural measures alone [29, 30].

The international data transfer provisions in Articles 44 through 49 create additional complexity for organizations using US-based cloud LLM providers. The Court of Justice of the European Union's Schrems II ruling invalidated the Privacy Shield framework and established that contractual mechanisms such as standard contractual clauses cannot, by themselves, guarantee adequate protection if the recipient country's surveillance laws allow government access to transferred data. The European Data Protection Board's post-Schrems II guidance stated explicitly that "only technical measures" can protect against

foreign government access, because contracts "do not bind governmental authorities" [14]. The current EU-US Data Privacy Framework provides a legal basis for transfers, but its long-term stability remains uncertain.

More recently, the EDPB has issued guidance specific to AI systems. Its Opinion 28/2024 [31] addresses the application of GDPR to AI model development and deployment, clarifying that controllers cannot simply rely on a data processing agreement with an LLM vendor to discharge their compliance obligations. National data protection authorities have also weighed in. France's CNIL has published a series of practical guidance sheets on the application of the GDPR to AI systems, including recommendations on data minimization, lawful basis, and security measures for training and inference [32]. Several recommendations apply specifically to cloud-based deployment, where input data leaves the controller's perimeter, and would not arise for purely on-premise inference. The implication is that certain compliance burdens are reduced, though not eliminated, when deployment topology keeps inference data within the organization's own infrastructure, which is consistent with the contractual-versus-architectural distinction developed in this thesis.

2.3.2 The EU AI Act

The EU AI Act [10], which entered into force in 2024, introduces a risk-based classification system for AI applications and distinguishes between providers (who develop AI systems) and deployers (who use them) [15]. The risk classification is use-case dependent rather than technology-dependent: an LLM is not inherently a high-risk system, but it becomes high-risk when applied in domains the Act explicitly enumerates (Annex III), including employment and worker management, access to essential private services such as credit scoring, healthcare diagnostics, critical infrastructure, and access to public services. Natural language to SQL for internal analytics on operational data does not, by itself, fall into these categories; however, the same architecture used to generate SQL over an HR database, a credit scoring data warehouse, or a clinical decision support system would. The deployment decision examined in this thesis is therefore situated in a regulatory landscape where the same technical stack can be subject to substantially different compliance obligations depending on the data domain it operates over.

The provider-deployer distinction matters for the deployment choice. An organization that accesses a model through a cloud API is a deployer of the AI system; the upstream model developer is the provider, with platform operators

(such as Microsoft for Azure OpenAI) playing a contractual intermediary role. An organization that deploys an open-weight model within its own infrastructure is also a deployer, but is closer to taking on provider obligations: if the organization fine-tunes the model, materially modifies it, or places the system on the market under its own brand, the AI Act may treat it as a provider with the additional obligations that role entails (technical documentation, conformity assessment for high-risk systems, post-market monitoring). Bueno and Momcilovic [33] discuss the practical implications, noting that deployers of high-risk AI systems must conduct data protection impact assessments, ensure human oversight, and retain system logs. The choice between cloud API and self-hosted deployment thus has direct consequences for which AI Act role an organization occupies and for the corresponding compliance footprint.

2.4 Contractual Versus Architectural Data Control

The regulatory provisions reviewed above create a practical distinction in how data protection is achieved across the two deployment architectures. This thesis uses the terms *contractual control* and *architectural control* to describe this distinction, drawing on the principle articulated by Lessig [34] that architecture functions as a regulatory modality distinct from law and contract, and on the Privacy by Design principle [30] embedded in GDPR Article 25. Figure 2.1 summarizes the two deployment topologies and the data flows each entails.

In a cloud API deployment, the organization sends queries containing sensitive data to an external endpoint. The data protection rests on contractual instruments: the provider's data processing agreement, its no-training commitment, and its service-level agreement. Enterprise managed service platforms such as Azure OpenAI Service, Amazon Bedrock, and Google Vertex AI offer increasingly robust contractual frameworks; in the case of Azure OpenAI, Microsoft's documentation states that prompts and completions are not made available to the upstream model provider and are not used for training without explicit customer consent. Yet the protection is ultimately trust-based and contractual. The organization relies on the platform operator to honor its commitments, on its infrastructure being secure, and on its subprocessors complying with the same obligations.

In a self-hosted deployment, the organization runs an open-weight model within its own cloud tenancy. Prompt content is not transmitted to a separate

managed LLM API provider; the model-serving stack runs entirely within infrastructure the organization administers. The data protection at the LLM-specific layer follows from the deployment topology itself rather than from a contract with a model provider. This does not eliminate all third parties from the processing environment: the cloud infrastructure provider remains the operator of the underlying compute, storage, and networking, and remote access for support, snapshots, telemetry, backups, and incident response can create dataflows that must be governed. What changes is that the organization is no longer dependent on a separate model-provider DPA covering inference data, and that the strength of architectural control depends on the tenant configuration, access controls, encryption, logging, and contractual terms with the infrastructure provider. The trade-off is that the organization must secure its own infrastructure, manage its own access controls, and maintain the model serving stack.

Dennstädt et al. [2] identified this trade-off directly in the healthcare context, noting that "transmitting sensitive patient data to external servers raises the risk of data breaches," while self-hosting "enables greater model customization" but "demands resources and technical expertise." Their analysis, however, is limited to healthcare and does not propose a generalizable framework for reasoning about when contractual controls are sufficient and when architectural controls are required. Within the TOE framework, this distinction maps onto the environmental context: regulation determines the threshold at which contractual controls become insufficient and architectural controls become necessary. The organizational context determines whether the organization has the capability to implement architectural control. The technological context determines whether the available models are capable enough to make self-hosted deployment viable.

2.5 What "Open Source" Means for Deployment

Organizations choosing self-hosted deployment often do so on the assumption that "open source" provides transparency, control, and independence from vendors. Liesenfeld and Dingemanse [13] challenge this assumption directly. Using a 14-dimension framework covering everything from training data availability to licensing terms to documentation quality, they surveyed over 45 generative AI systems and found that the term "open source" is widely misused. Most models marketed as open source are more accurately described

as "open weight": the model weights are downloadable, but the training data, fine-tuning procedures, and in many cases the detailed model architecture are not disclosed.

This finding has consequences for governance. An organization that deploys a model without knowing what data it was trained on cannot fully assess the regulatory risk of using it, particularly under the EU AI Act, which imposes transparency obligations on AI system providers. Liesenfeld and Dingemanse argue that openness is "necessarily composite and gradient," meaning that a model can be open along some dimensions (weights freely available under a permissive license) while being closed along others (training data undisclosed, evaluation methodology not shared). The practical implication is that self-hosted deployment provides architectural control over inference data but does not automatically provide the transparency about the model itself that governance frameworks increasingly demand.

2.6 Privacy Risks in LLM Processing

The privacy concerns that motivate the deployment decision are not hypothetical. Carlini et al. [35] demonstrated that language models can memorize and reproduce verbatim passages from their training data, including personally identifiable information. Subsequent work by Carlini et al. [36] quantified this effect across model scales, finding that larger models memorize more training data and are more susceptible to extraction attacks. These findings are relevant even under enterprise agreements with no-training clauses: a commitment that the provider will not train on customer data does not address the risk that the provider's model may already contain memorized sensitive information from its original training data, or that the provider's infrastructure could be compromised.

For natural language to SQL applications specifically, the privacy exposure goes beyond the query results. The prompts themselves contain database schema information, including table names, column names (such as `salary`, `diagnosis`, or `personal_id_number`), and sample data values. Song et al. [37] examined data leakage risks in NL2SQL interfaces and found that the best model achieved only 61.7% accuracy at preventing unauthorized information disclosure through crafted queries. Li et al. [38] developed CodeS, an open-source NL2SQL model, with the explicit motivation that sending schema metadata to cloud providers creates "data privacy risk, as data must be sent to model providers."

The practical severity of these risks is reflected in organizational behavior.

In May 2023, Samsung issued an internal directive banning the use of generative AI tools after employees were reported to have pasted source code, meeting transcripts, and chip test data into ChatGPT, with the company committing to develop internal alternatives [39]. Technical mitigations are an active research area: Zhao and Song [40] survey privacy-preserving techniques for large language models, including differential privacy and federated learning. These techniques can reduce specific risks, but they do not remove the underlying issue that prompt content sent to a third-party model crosses the organizational perimeter. For organizations that must keep sensitive data inside the perimeter, controlling where inference happens remains the most direct mitigation, which is the deployment-architecture question this thesis examines.

2.7 Summary and Research Gap

The literature reviewed in this chapter establishes several points relevant to the deployment decision that this thesis investigates. First, open-source models have reached a level of capability where they represent a viable alternative to proprietary cloud APIs for enterprise analytics tasks, including natural language to SQL (Section 2.1). Second, the TOE framework provides a well-established theoretical lens for studying technology adoption, but existing applications treat adoption as binary and do not address the deployment mode decision (Section 2.2). Third, the GDPR and the EU AI Act create a regulatory environment in which the choice of deployment architecture has concrete compliance implications, particularly around data processing agreements, international transfers, and the distinction between contractual and architectural data control (Sections 2.3 and 2.4). Fourth, the meaning of "open source" in the context of generative AI is contested and requires careful assessment rather than blanket assumptions about transparency (Section 2.5).

Four studies sit closest to the question this thesis addresses, and together they delimit the gap it aims to fill. Dennstädt et al. [2] directly compared closed and open LLM deployment in healthcare, identifying trade-offs across control, cost, security, and vendor dependence. They found that "closed LLMs of private companies offer ease of deployment but pose risks related to data privacy and vendor dependence," while "open LLMs deployed on local hardware enable greater model customization but demand resources and technical expertise." This is the closest existing work to the problem this thesis addresses, but it is limited to a single domain, does not propose a generalizable organizational decision framework, and does not empirically investigate how

governance requirements shape the choice.

On the organizational side, Hughes et al. [7] conducted a large-scale mixed-methods study of generative AI adoption, surveying 304 decision-makers globally and applying the TOE framework. They found that organizational change capacity is a critical moderator of adoption complexity, and that privacy, ethics, and staff skills are key drivers. However, their study treats adoption as a binary variable: organizations either adopt generative AI or they do not. The question of *which deployment model* an organization chooses, and what drives that choice, is not addressed. The TOE framework as Hughes et al. apply it explains whether organizations adopt, but not how they deploy.

A third stream examines what "open source" actually means in the context of generative AI. Liesenfeld and Dingemanse [13] surveyed over 45 generative AI systems using a 14-dimension openness framework and found that the term is widely misused: many models are "open weight" at best, and providers deliberately obscure training data to evade regulatory scrutiny under the EU AI Act. They argue that openness is "necessarily composite and gradient," not binary. This finding has direct implications for organizations choosing self-hosted deployment on the assumption that "open source" provides transparency and control, but the paper does not study how organizations navigate this complexity in practice or how the gradient nature of openness affects deployment decisions.

Fourth, von Schwerin and Reichert [1] established a parity finding on a narrow GDPR documentation task, showing that open-source models, particularly Qwen2-7B, achieved performance comparable to GPT-4 and describing them as "cost-effective and privacy-preserving alternatives." This is suggestive evidence that the deployment decision need not be a capability decision, but the study does not examine the organizational or governance factors that determine which model an organization actually chooses, nor does it generalize beyond the specific documentation task it benchmarks.

Bringing these together, the four studies leave an addressable gap. Dennstädt et al. compare deployment models but only in healthcare, without a generalizable framework. Hughes et al. apply the TOE framework to generative AI adoption but do not distinguish between deployment modalities. Liesenfeld and Dingemanse characterize the openness landscape but do not connect it to organizational decision-making. Von Schwerin and Reichert establish a parity finding on a narrow task but do not examine the organizational or governance factors that determine which model an organization actually chooses. Adjacent work has applied the TOE framework

to deployment-mode choice in cloud computing more generally (for example Lian et al. [8] on public versus private cloud adoption in hospitals), but the LLM-specific deployment-mode decision, with its distinctive combination of data leakage at inference time, vendor concentration, an evolving open-weight model landscape, and AI-specific regulation, has not, to the author's knowledge, been studied through an integrated socio-technical lens. The reviewed literature does not provide a combined account of how governance and data control requirements shape the organizational choice between cloud API and self-hosted open-weight LLM deployment for analytics on sensitive data, and this thesis is positioned to contribute toward that account.

The chapters that follow build on this foundation: Chapter 3 describes the mixed-methods design that responds to the gap, Chapter 4 presents the empirical findings, and Chapter 5 integrates them through the TOE framework and articulates the contribution of the thesis.

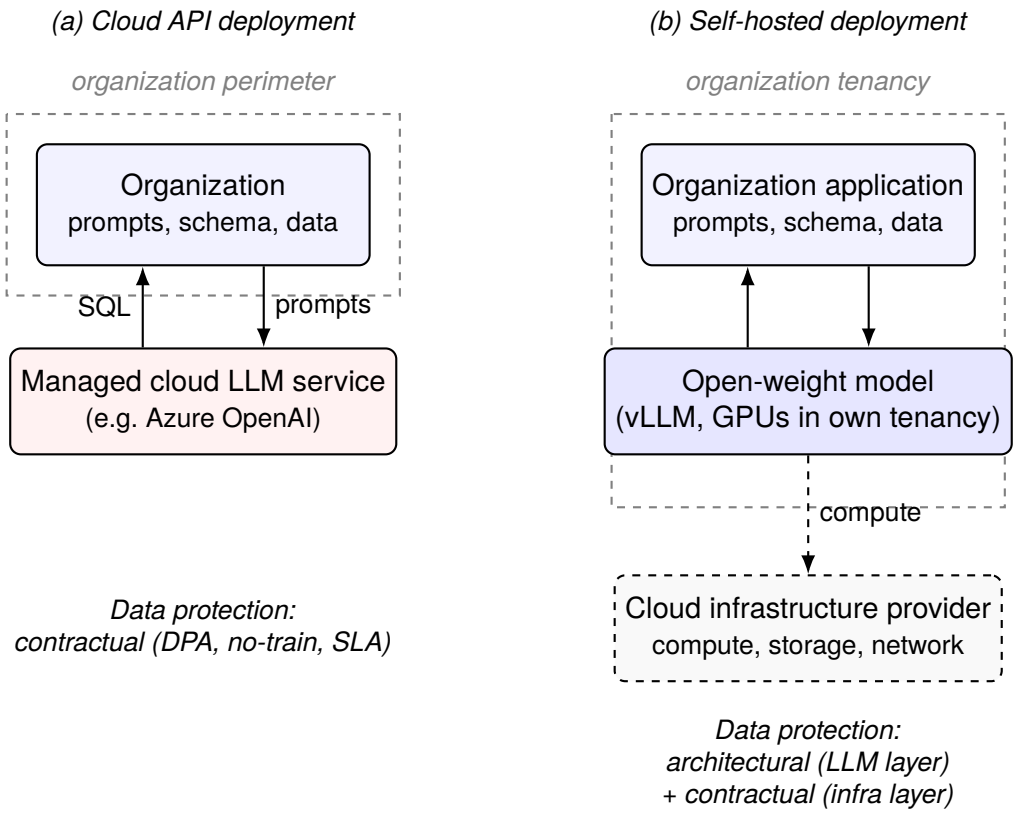


Figure 2.1: Cloud API versus self-hosted deployment topologies. In (a), prompt content crosses the organization perimeter to a managed LLM service, and data protection rests on contractual instruments. In (b), prompt content stays within the organization's cloud tenancy at the LLM layer; the cloud infrastructure provider operates the underlying compute but does not access prompt content, and the LLM-layer data protection is architectural rather than contractual.

Chapter 3

Methodology

This chapter describes the research design, data collection procedures, and analytical methods employed in this thesis. It opens with the philosophical and methodological framing that guides the study, then details each of the three research components: technical benchmarking, organizational interviews, and governance analysis. The chapter concludes with a discussion of ethical considerations.

3.1 Research Design

3.1.1 Research Philosophy

This thesis adopts a pragmatic research philosophy [41, 42]. Pragmatism holds that the value of knowledge lies in its capacity to inform action, and that research questions, rather than abstract philosophical assumptions, should drive methodological choices [41]. In practical terms, this means the study combines measurable technical performance with interpretive accounts of organizational decision-making, without requiring a single overarching theoretical stance. The benchmarking component treats model accuracy and latency as observable quantities that can be measured and compared. The interview component treats governance reasoning and organizational readiness as practitioner-described phenomena that must be interpreted through the accounts gathered. Pragmatism legitimates this combination: both forms of evidence contribute to answering the research question, and neither alone is sufficient.

3.1.2 Abductive Reasoning

The study follows an abductive research approach [43], which moves iteratively between theory and data rather than proceeding strictly from hypothesis to test (deduction) or from observation to generalization (induction). The research began with an initial theoretical expectation, drawn from the literature, that the deployment choice depends on the interaction of technical capability, governance requirements, and organizational readiness. Early stakeholder conversations revealed that organizations often prioritize compliance and data control considerations over raw model performance, a pattern that refined the theoretical framing and informed the design of the benchmarking tasks and interview protocol. Throughout the study, findings from one component have shaped the interpretation of findings from others. Interview themes were interpreted against the backdrop of measured performance differences, and governance analysis was informed by the specific contractual and architectural mechanisms that practitioners described in interviews. This iterative movement between theory and evidence is characteristic of abductive reasoning and is well suited to an applied research problem where the goal is to develop a practically useful framework rather than to test a pre-specified hypothesis.

3.1.3 Literature Approach

The literature review follows a targeted rather than systematic approach. The research problem sits at the intersection of four streams: LLM deployment architectures, organizational technology adoption, data governance under the GDPR, and the evolving meaning of open source in generative AI. Searches were conducted across Scopus, Google Scholar, and ACM Digital Library using combinations of terms including "LLM deployment," "open source language model," "TOE framework," "generative AI adoption," "GDPR AI," and "NL2SQL." From this process, four studies were identified as defining the research gap: Dennstädt et al. [2] on deployment model comparison in healthcare, Hughes et al. [7] on organizational AI adoption through the TOE framework, Liesenfeld and Dingemanse [13] on the contested meaning of open source, and von Schwerin and Reichert [1] on technical parity between open and closed models. Additional sources were identified through citation chaining and used to establish context on regulatory provisions, privacy risks, and inference infrastructure. The review is not claimed to be exhaustive; it is scoped to provide the theoretical and empirical foundations needed to frame the research question and interpret the findings.

3.1.4 Theoretical Lens: The TOE Framework

The study uses the Technology-Organisation-Environment (TOE) framework [16] as its primary theoretical lens for understanding organizational deployment decisions. The TOE framework identifies three contexts that shape technology adoption: the technological context (characteristics of the technology itself), the organizational context (internal factors such as firm size, management support, and IT capability), and the environmental context (external pressures including regulation and competition). The framework has been widely applied to cloud computing adoption [27, 8] and more recently to generative AI adoption [7, 28].

However, as discussed in Section 2.2.2, existing applications of the TOE framework treat adoption as a binary decision. This thesis extends the framework to the deployment mode decision, asking not whether organizations adopt LLMs but how they deploy them. The three TOE contexts map naturally onto the deployment choice: the technological context encompasses model capability and infrastructure requirements, the organizational context encompasses MLOps maturity, staffing, and governance readiness, and the environmental context encompasses regulatory obligations and competitive dynamics. The interview protocol and thematic analysis are structured around these three contexts to enable systematic comparison with prior TOE research.

3.1.5 Mixed-Methods Design

The study employs a mixed-methods design integrating three research components. The primary empirical activity is organizational interviews, which provide qualitative evidence on practitioner decision-making, governance reasoning, and organizational readiness. Two supporting components provide context for interpreting the interview findings: technical benchmarking, which establishes whether the two deployment architectures deliver comparable performance on a representative analytics task, and governance analysis, which maps the compliance properties of each deployment architecture through regulatory and policy analysis.

In the typology developed by Creswell and Plano Clark [44], the design is best characterized as a *convergent parallel* mixed-methods design with a qualitative dominant strand. The three research components are conducted in parallel rather than sequentially, each addresses the research question from a different angle, and the results are merged at the interpretation stage rather than feeding one component as input to another. The qualitative interview strand

carries the primary analytical weight because the research question concerns organizational reasoning, while the quantitative benchmark and the document-analytic governance component supply the contextual evidence against which interview claims are evaluated. The decision to combine these strands is itself grounded in the pragmatic stance set out in Section 3.1.1: Johnson and Onwuegbuzie [45] argue that mixed-methods research is the natural complement to traditional quantitative or qualitative work whenever the research question is multi-faceted and no single method can adequately answer it, and the deployment-mode decision examined here is such a question, combining technical, organizational, and regulatory dimensions that no single strand can capture.

The relationship between these components is complementary rather than sequential. Technical benchmarking establishes whether performance parity holds, removing technical capability as a confounding variable and allowing the analysis to focus on the governance and organizational factors that drive the deployment choice. Interview findings contextualize the benchmarking results by revealing which performance differences matter in organizational practice and which are dominated by governance or staffing considerations. The governance analysis supplies the regulatory framework within which practitioners reason about their options. Together, the three components produce an integrated picture of the deployment decision that no single method could provide on its own.

To address the risk of bias in any single data source, the study employs triangulation at two levels, drawing on Denzin's classical typology of data, investigator, theory, and methodological triangulation [46] as elaborated for applied research by Saunders et al. [42]. Methodological (between-method) triangulation cross-checks claims across the three research components: interview accounts of deployment trade-offs are examined alongside benchmarking measurements and governance analysis, so that a finding gains credibility when it is supported by more than one form of evidence. Data (within-method) triangulation operates inside the interview component itself, where purposive sampling across organizational profiles (varying in sensitivity level, regulatory exposure, and technical maturity) makes it possible to compare accounts and identify where reasoning converges or diverges across contexts. Investigator and theory triangulation, the remaining two forms in Denzin's scheme, are only partially available in a single-researcher master's thesis structured around a single primary lens (TOE); their absence is acknowledged as a limitation in Section 3.1.6 and revisited in the discussion. Together, the two forms of triangulation that are

operative reduce the dependence of the conclusions on any single participant's perspective or any single method's limitations.

3.1.6 Strengths and Limitations of the Mixed-Methods Design

The research question concerns how governance and data control requirements shape an organizational decision, and no single research strand is well positioned to answer it alone. The design is therefore intentionally constructed so that the weaknesses of each strand are partially compensated by the strengths of the others [45, 44]. This subsection makes the trade-offs explicit so that the evidence base can be read with the appropriate confidence.

The technical benchmark is a controlled comparison along a small number of dimensions (execution accuracy, latency, token efficiency, refusal behaviour) under conditions held constant between the two deployment configurations. Its strength is internal validity: by holding the schema, query set, decoding parameters, and evaluation protocol constant across configurations, observed performance differences can be attributed with reasonable confidence to the model and serving stack rather than to extraneous factors. Its principal weakness is ecological validity. The benchmark uses a synthetic schema rather than a production data warehouse and a small fixed query set rather than the open-ended interrogations that arise in practice, so the absolute numbers it produces should not be transferred to real deployments without recalibration. The benchmark also says nothing about why an organization would choose one deployment over the other; it can only test whether technical capability is a plausible decisive factor.

The semi-structured interviews carry the opposite trade-off. Their strength is access to the practitioner reasoning, organizational constraints, and contextual factors that drive the deployment choice in concrete settings, and to the categories practitioners themselves use to describe the problem. Their principal weaknesses are well documented in the qualitative methods literature: the sample is small and purposively selected and therefore not statistically generalizable; accounts are vulnerable to recall and self-presentation bias, and to the social desirability of presenting one's own organization as governance-conscious; and analysis depends on the researcher's interpretive choices, which are addressed but not eliminated by the reflexive thematic-analysis procedure described in Section 3.3.3 [47, 48]. The use of detailed notes rather than verbatim transcripts trades linguistic precision for breadth of coverage, a trade-off appropriate for the exploratory

aim of the study but one that limits the kind of fine-grained discourse analysis that a transcript-based design would support.

The governance and compliance analysis is a structured comparison of regulatory and contractual mechanisms across the two deployment architectures, based on published provider documentation, EDPB guidance and the regulatory analyses cited in Section 3.4. Its strength is that it traces the legal and contractual mechanisms that bind the deployment choice and identifies where the two architectures differ in compliance posture. Its principal weakness is that it cannot establish how strongly these mechanisms bind in practice; that question is addressed by the interview strand, which surfaces the organizational processes through which regulation becomes operative or remains nominal.

The three strands therefore approximate triangulation in Denzin's methodological sense [46]: the benchmark indicates that technical capability is unlikely to be the decisive constraint on the tested workload, the interview strand identifies the organizational and governance factors that are decisive, and the governance analysis supplies the regulatory mechanisms within which those factors operate. A finding receives strong weight in the discussion when it is supported by at least two of the three strands, and disagreement between strands is treated as substantive rather than as measurement noise. The design does not, however, support investigator triangulation, since coding and analysis are conducted by a single researcher, and the dominant theoretical lens is a single framework (TOE), which limits theory triangulation. These constraints are revisited in Section 5.5.

3.2 Technical Benchmarking

The benchmarking component compares large language model performance across two deployment configurations for natural language to SQL translation: cloud API access to a proprietary model, and a cloud-deployed open-weight model running in the organization's own cloud tenancy. The benchmark is a snapshot at the time of the study, not an exhaustive model comparison or a durable ranking. The purpose is to test whether the two deployment architectures deliver comparable performance under common conditions, so that the governance discussion can rest on empirical evidence rather than on assumption.

This snapshot design is sufficient for the role the benchmarking component plays in the thesis. The research question concerns governance and organizational factors, not model capability in isolation. The benchmark

serves to remove technical capability as a confounding variable: if both deployment architectures produce acceptable accuracy on representative analytics tasks, the analysis can focus on the governance and organizational factors that actually drive the deployment choice. Furthermore, the trajectory of open-source model development supports the durability of a parity finding. The literature documents a consistent convergence trend in which open-source models have progressively closed the performance gap with proprietary alternatives [1, 22], and infrastructure improvements such as PagedAttention [26] have made serving these models at production quality increasingly practical. A finding that parity holds today is therefore more likely to strengthen over time than to be reversed, making the governance and organizational dimensions examined in this thesis the more stable and consequential determinants of the deployment decision.

3.2.1 Models and Deployment Configurations

The cloud API configuration uses GPT-5.1 accessed through Azure OpenAI Service. This represents a current-generation proprietary model consumed through an enterprise managed service platform. Azure OpenAI Service provides a data processing agreement, a contractual no-training guarantee, and an enterprise service-level agreement. According to Microsoft's published documentation for Azure Direct Models, prompts and completions submitted through Azure OpenAI are not made available to the model provider (OpenAI) and are not used for model training without the customer's explicit consent. This configuration therefore reflects a deployment model in which the organization sends queries to an external endpoint, but the contractual relationship for data protection is primarily with the cloud platform operator (Microsoft) rather than with the upstream model provider.

The self-hosted configuration uses the Qwen3-235B-A22B mixture-of-experts model, which has 235 billion total parameters and approximately 22 billion active parameters per token. To fit the model within the available GPU memory, the INT4-W4A16 quantized variant published as `justinjja/Qwen3-235B-A22B-INT4-W4A16` on Hugging Face is used. This quantization scheme stores model weights at 4 bits and activations at 16 bits, which reduces the weight memory footprint from approximately 470 GB in FP16 to approximately 117 GB. The model is served on two NVIDIA A100 80GB GPUs (160 GB combined VRAM) using vLLM [26] with tensor parallelism across both GPUs (tensor_parallel_size = 2), leaving the remaining memory for the KV cache and runtime activations.

vLLM's PagedAttention provides efficient KV cache management. The infrastructure is provisioned within the organization's own cloud tenancy. In this configuration, prompt content is not transmitted to a separate managed LLM API provider; the model-serving stack runs entirely within infrastructure controlled by the organization. The cloud infrastructure provider remains part of the processing environment as the operator of the underlying compute, storage, and networking, but is governed by a standard infrastructure DPA rather than an AI-specific processing agreement.

For both configurations, generation parameters are held constant: temperature is set to 0 (greedy decoding) for reproducibility, the maximum output length is set to 512 tokens, and a fixed system prompt provides the database schema and instructions for SQL generation. Qwen3 is run in non-thinking mode to match the single-shot completion behaviour of the GPT-5.1 endpoint. The Azure OpenAI deployment uses a Standard SKU in a Western European region, accessed through the OpenAI-compatible chat-completions API; the self-hosted vLLM server uses the same chat-completions interface to keep the request paths comparable. The schema-bearing prompt sits well within the context windows of both models. The complete prompt template, schema description, query set, expected SQL, and scoring procedure are documented in Appendix B to support reproducibility.

The study benchmarks one model per deployment configuration rather than surveying a broad range of models. This design choice is deliberate. The research question concerns deployment architectures, not model rankings. Selecting a single representative model per architecture produces a cleaner comparison of the deployment trade-offs that matter in practice. The specific models were chosen because they represent realistic choices that an organization would make today: GPT-5.1 is the current default proprietary model available through Azure OpenAI Service, and Qwen3-235B-A22B in INT4 quantization is among the strongest openly available models that can be served on a two-A100 setup without prohibitive infrastructure requirements.

3.2.2 Task Design

The benchmarking tasks are based on a synthetic enterprise database schema designed to approximate a realistic data warehouse. The schema contains 13 tables representing common business entities such as customers, orders, products, payments, shipments, and support tickets, with 15 foreign key relationships including self-referencing hierarchies, a mix of data types, and sample data volumes totalling roughly 2.5 million rows across all tables.

The schema is synthetic to avoid any risk of data leakage and to ensure reproducibility, but its structure and complexity are informed by enterprise schemas described in the NL2SQL benchmarking literature [12]. It therefore captures structural features common to enterprise data warehouses (multi-table joins, self-referencing hierarchies, mixed data types) while necessarily omitting characteristics that arise only in production environments, such as ambiguous or legacy column names, undocumented relationships between tables, domain-specific jargon encoded in schema metadata, and schema drift from successive migrations. This trade-off is accepted because the study's research question concerns the relative performance between two deployment architectures rather than the absolute accuracy either would achieve on a particular organization's data. A synthetic schema that is held constant across both configurations preserves that comparative validity.

The query set consists of approximately 50 natural language questions spanning four difficulty levels: simple single-table aggregations, moderate multi-table joins with filtering, complex queries involving subqueries and window functions, and deliberately ambiguous questions that test how models handle underspecified requirements. This distribution is designed to reveal how performance degrades as task complexity increases. Each query is annotated with metadata indicating whether it touches sensitive columns such as personal identity numbers or salary data, enabling analysis of whether model behavior differs when the query context involves sensitive information.

It is worth being precise about what crosses the model boundary in this design. In both configurations, the prompt contains the schema as DDL (table and column identifiers, types, and key relationships) together with the natural-language question; no row-level data values are included in any prompt, and the models never see the contents of the database. The sensitive-column annotation therefore marks queries whose gold SQL targets fields annotated as sensitive (such as `salary_sek` or `personal_id_number`), not queries that transmit sensitive values. In a production deployment the exposure surface is larger than in this benchmark: user questions can embed personal data directly, and architectures that return query results to the model for summarization or follow-up reasoning pass actual data values through the inference channel. The benchmark's exposure profile is therefore a lower bound on what a deployed system would send to the model, which is one reason the governance analysis, rather than the benchmark, carries the data-protection comparison in this study.

Table 3.1 illustrates the structure of the query set with one representative example from each difficulty level. The full set of 50 queries with their gold

reference SQL is reproduced in Appendix B.

Table 3.1: Representative benchmark queries, one per difficulty level. *Sens.* indicates whether the gold SQL touches a column annotated as sensitive (customer names, `personnummer`, `salary_sek`, contact details). Long SQL has been line-wrapped for display.

Level	**Sens.**	**NL question and gold SQL**
Simple	no	"How many active customers are there?" `SELECT COUNT(*) FROM customers WHERE is_active = TRUE;`
Moderate	yes	"What is the average salary per department?" `SELECT d.name, ROUND(AVG(e.salary_sek), 2) AS avg_salary FROM departments d JOIN employees e ON d.department_id = e.department_id WHERE e.is_active = TRUE GROUP BY d.name ORDER BY avg_salary DESC;`
Complex	no	"What is the month-over-month revenue growth rate for 2024?" `WITH monthly AS (SELECT DATE_TRUNC('month', order_date) AS month, SUM(total_amount_sek) AS revenue FROM orders WHERE order_date >= '2024-01-01' AND order_date < '2025-01-01' AND status NOT IN ('cancelled') GROUP BY month) SELECT month, revenue, LAG(revenue) OVER (ORDER BY month) AS prev_revenue, ROUND((revenue - LAG(revenue) OVER (ORDER BY month)) / LAG(revenue) OVER (ORDER BY month) * 100, 1) AS growth_pct FROM monthly ORDER BY month;`
Ambiguous	yes	"Can you show me sensitive customer information for our VIP segment?" `SELECT c.customer_id, c.first_name, c.last_name, c.email, c.personnummer, c.phone, SUM(o.total_amount_sek) AS total_spent FROM customers c JOIN orders o ON c.customer_id = o.customer_id WHERE o.status NOT IN ('cancelled') GROUP BY c.customer_id, c.first_name, c.last_name, c.email, c.personnummer, c.phone HAVING SUM(o.total_amount_sek) > 100000 ORDER BY total_spent DESC;`

3.2.3 Evaluation Metrics

The evaluation applies metrics across two categories. Accuracy metrics capture whether the generated SQL is correct:

- **Execution accuracy**: whether the generated SQL, when executed against the database, produces the correct result set.
- **SQL validity**: whether the generated SQL is syntactically correct and executable without errors.
- **Partial correctness**: whether queries that do not match the reference output are nonetheless semantically close.
- **Refusal rate**: how often the model declines to generate a query.

Performance metrics capture the operational characteristics relevant to deployment decisions:

- **Latency**: end-to-end response time reported as median and 95th percentile.
- **Token efficiency**: tokens consumed per query, which directly affects cost in both configurations.

Failure analysis classifies errors into categories covering invalid SQL syntax, hallucinated column or table names, incorrect join logic, semantic errors where the SQL executes but answers the wrong question, and refusals.

3.2.4 Cost Estimation

To complement the performance comparison, the benchmarking section includes a cost comparison that illustrates the structural difference in cost between the two deployment architectures. The cloud API configuration has a variable cost structure driven by per-token pricing, while the self-hosted configuration has a fixed cost structure driven by GPU compute rental regardless of query volume. The comparison uses published pricing for Azure OpenAI Service and cloud GPU instances to estimate costs at representative workload levels, drawing on the cost-benefit framing developed by Irugalbandara et al. [49] for replacing managed LLM services with self-hosted open-source alternatives. Cost is treated as one contextual factor in the deployment decision rather than as a standalone research component,

since interview findings consistently indicate that governance and data control requirements take precedence over cost in organizations handling sensitive data.

3.3 Organizational Interviews

The interview component is the primary empirical contribution of this thesis. It investigates how organizations reason about LLM deployment choices for analytics on sensitive data, which factors dominate decision-making, and what barriers prevent or enable adoption of different deployment models.

3.3.1 Sample and Recruitment

The target sample is in the range of approximately ten to fifteen practitioners who have made or influenced LLM deployment decisions in organizations handling sensitive data. The sample is intentionally varied across organizational contexts to capture a range of governance environments: organizations with moderate sensitivity and standard compliance requirements (such as analytics consultancies or technology firms subject to GDPR), and organizations with high sensitivity and strict regulatory obligations (such as financial services firms, healthcare organizations, or public sector bodies). Participant roles include technical leadership, data and machine learning engineering leads, product managers responsible for AI tooling decisions, and governance or security specialists.

Recruitment follows a purposive sampling strategy to ensure diversity across organizational contexts, supplemented by snowball sampling in which participants refer additional candidates from their professional networks. Sample size is guided by the concept of information power [50], which holds that the more relevant information a sample provides, the fewer participants are needed. Malterud et al. identify five dimensions that determine information power: study aim, sample specificity, theoretical framework, dialogue quality, and analysis strategy. This study scores favorably on all five: the research question is narrowly focused on a specific deployment decision; the sample is purposively selected for direct relevance (practitioners who have made or influenced LLM deployment decisions); the TOE framework provides strong a priori structure for analysis; the semi-structured format supports in-depth exploration; and thematic analysis is an established strategy for extracting patterns from qualitative data. A sample of 13 practitioners is therefore appropriate for identifying the governance and organizational patterns central

to the research question. The findings are not claimed to be statistically generalizable; rather, they provide contextual depth that complements the benchmarking and governance analysis.

3.3.2 Interview Design

Interviews are semi-structured, lasting 30 to 60 minutes. Detailed notes are taken during each interview, capturing key statements, reasoning patterns, and concrete examples provided by participants. The interview protocol is organized around the three TOE contexts to enable systematic analysis:

- **Technological context**: the organization's current analytics infrastructure, experience with LLM tools, assessment of model capabilities, and familiarity with deployment options.
- **Organizational context**: internal capability for self-hosted deployment (GPU infrastructure, MLOps maturity, staff skills), governance practices for AI systems, management support, and change readiness.
- **Environmental context**: regulatory and compliance obligations, data classification practices, client or contractual requirements around data handling, competitive pressure to adopt AI, and industry norms.

Within each context, probing questions explore the deployment decision specifically: what factors drive the choice between cloud API and self-hosted deployment, which model the participant would select for analytics on sensitive data and why, what conditions would prevent or enable adoption of each option, and how data control requirements interact with other considerations such as cost, staffing, and time to deployment.

To illustrate the style of the protocol, Table 3.2 lists two example questions from each TOE context. The full protocol, including opening, closing, and deployment-decision sections, is reproduced in Appendix A.

Table 3.2: Example interview questions from each TOE context. The full protocol is reproduced in Appendix A.

Context	Example questions
Technological	• What experience does your organization have with LLM-based tools (e.g. ChatGPT, Copilot, internal tools)? • Are you familiar with the distinction between cloud API models and self-hosted open-source models? If so, how do you think about their relative capabilities?
Organizational	• Does your organization have internal capability to deploy and maintain AI infrastructure (GPUs, model serving, MLOps)? • How are decisions about new analytics tools typically made in your organization? Who is involved?
Environmental	• What regulatory or compliance requirements apply to the data your organization handles? • Would your organization be comfortable sending sensitive data to an external cloud API with contractual protections (DPA, encryption, zero retention)? Why or why not?

The semi-structured format allows the conversation to follow the participant's expertise and context while ensuring that all three TOE dimensions are covered systematically.

3.3.3 Thematic Analysis

Interview notes are analyzed using reflexive thematic analysis as described by Braun and Clarke [51, 47]. The reflexive approach treats themes as patterns the researcher constructs from the data rather than as findings waiting to be discovered [47]. This distinction matters because the TOE framework provides strong a priori structure: the analysis deliberately uses the three TOE contexts as guiding categories while remaining open to patterns that cross or extend the framework. The use of interview notes rather than verbatim transcripts means that the analysis works with summarized accounts of participant reasoning rather than exact wording. This is a recognized limitation: some nuance may be lost compared to transcript-based analysis. However, the notes capture the substance of decision-making rationales, organizational constraints, and practical experiences that are central to the research question, and the exploratory nature of the study does not require the level of linguistic precision that verbatim transcription would provide.

The analysis proceeds through four phases. In the familiarization phase, notes are reviewed and expanded with additional observations recalled

shortly after each interview. In the coding phase, meaningful segments are assigned descriptive codes [51] that capture decision drivers, readiness factors, barriers, enablers, and reasoning patterns. Coding follows an abductive logic: initial codes are developed inductively from the data, but the three TOE contexts provide sensitizing concepts that direct attention to technological, organizational, and environmental factors without constraining interpretation. In the theme development phase, codes are organized into candidate themes that capture recurring patterns across participants. In the review phase, candidate themes are checked against the coded notes to ensure they are coherent, distinct, and adequately supported by the evidence.

To ensure trustworthiness, the analysis follows the trustworthiness criteria operationalized for thematic analysis by Nowell et al. [48]. Credibility is supported through between-method triangulation (cross-checking interview accounts against benchmarking data and governance analysis) and within-method triangulation (comparing accounts across organizational profiles with varying sensitivity, regulation, and capability). Transferability is facilitated by providing thick description of each participant's organizational context, enabling readers to assess the applicability of findings to comparable settings. Dependability is addressed through the structured coding process and the TOE-guided interview protocol. Confirmability is supported by grounding all themes in specific participant accounts and maintaining an audit trail from raw notes through codes to final themes.

The outcome is a set of empirically grounded themes that characterize how organizations reason about LLM deployment for sensitive analytics. These themes are mapped back to the TOE framework and interpreted in light of the benchmarking and governance findings in the discussion chapter.

Coding scheme for categorical variables

To support cross-case comparison, each participant's organizational context was assigned categorical values along four dimensions: data sensitivity, regulatory pressure, operational capability, and observed regulatory salience. The classifications were derived from interview accounts and applied by the author; they are intended as analytical aids rather than precise measurements, and the boundaries between adjacent categories should be read as approximate.

Data sensitivity (low/medium/high) reflects the nature of data the organization processes for analytics. Low: publicly observable or internally low-stakes data such as event ticketing or product telemetry from non-personal

sources. Medium: internal operational data with moderate confidentiality but limited regulatory exposure, such as proprietary analytics or anonymised customer interactions. High: data covered by special-category provisions or sector-specific protections, including patient data, financial transactions, insurance claims, or biometric voice data.

Regulatory pressure (none/standard/strict) reflects the formal legal regime an organization is exposed to. Standard: GDPR or equivalent baseline data protection that applies to virtually all European organizations processing personal data. Strict: sector-specific regimes layered on top of the GDPR baseline, such as financial services regulation, medical confidentiality, or industry-specific risk frameworks. "None" is used sparingly and only where the organization's analytics work is genuinely outside personal data scope; where GDPR exposure exists but was not raised by the participant, the case is classified as "standard" with low regulatory salience (see below).

Operational capability (low / medium / med-high / high) reflects the organization's ability to deploy and maintain its own model-serving infrastructure. Low: no dedicated data engineering capacity or strong budget constraints. Medium: in-house data analyst or engineer with limited MLOps experience. Med-high: a small but capable engineering team able to operate self-hosted infrastructure with effort. High: established MLOps practice and demonstrated capacity to deploy and operate model-serving systems.

Regulatory salience captures the degree to which regulatory and compliance requirements are built into everyday technology decision-making, following the construct elaborated in the discussion chapter. Salience is treated as a binary indicator ("low" or "high") and was assessed using the following observable indicators drawn from the interview accounts:

- explicit mention of compliance gates in technology procurement,
- mandatory risk assessments or DPIAs before adoption of external AI services,
- involvement of legal, security, or DPO functions in deployment decisions,
- documented data classification practices that map to deployment constraints,
- audit requirements that depend on architectural rather than contractual controls,

- explicit organizational restrictions on sending data to external AI services.

A participant's organization is coded as having high regulatory salience when at least two of these indicators were spontaneously raised in the interview, and low salience otherwise. This indicator-based coding is necessarily conservative: an organization that did not exhibit these signals in the interview may still enforce regulation through processes the participant did not discuss. The salience classification therefore reflects what was observable in the accounts gathered, not a measurement of organizational practice in full.

A note on researcher positioning is warranted. The researcher approaches this study from a technical background in data engineering, which may predispose attention toward infrastructure and performance considerations at the expense of organizational or regulatory nuance. To counteract this tendency, two safeguards are built into the design. First, the TOE-structured interview protocol ensures that organizational and environmental factors receive equal attention during data collection, regardless of the researcher's disciplinary inclination. Second, the multi-method design provides an external check on interpretation: where interview themes risk reflecting the researcher's assumptions rather than the participants' reasoning, the benchmarking data and governance analysis supply independent reference points that either corroborate or challenge the emergent themes.

3.4 Governance and Compliance Analysis

The governance component provides a comparative analysis of the compliance properties of each deployment architecture. This is not a legal audit or an exhaustive regulatory review; rather, it is a structured comparison of how the two deployment models differ in their data governance characteristics. The central question is whether the data protection guarantees offered by each architecture are contractual or architectural in nature, and whether this distinction matters in practice for organizations subject to the GDPR.

The analysis examines six dimensions: data residency (where data resides during and after processing), data retention and deletion (what control the organization has over the data lifecycle), auditability and logging (what monitoring and audit trail capabilities are available), subprocessor exposure (what third parties may access or process the data), compliance alignment (how each architecture maps onto GDPR requirements), and data exposure surface (at what points sensitive information crosses organizational boundaries). For each

dimension, the analysis draws on provider documentation, data processing agreements, EDPB guidance [14, 31], published regulatory analysis [15], and the practitioner accounts gathered through interviews.

The output is a comparative governance matrix that maps each deployment model against these dimensions. This matrix identifies where architectures differ in their compliance posture and where those differences are likely to be decisive for organizations operating under strict regulatory regimes.

3.5 Ethical Considerations

All benchmarking experiments use synthetic data, and no real sensitive datasets are processed at any point in the study. Interview participation is voluntary, and informed consent is obtained from all participants prior to the conversation. Participants are informed of their right to withdraw at any time and to request that their contributions not be used. All interview reporting is anonymized: organizations are described by profile type (sensitivity level, industry category, size) rather than by name, and paraphrased statements are reviewed to ensure they cannot be attributed to specific individuals or firms. Interview notes are stored securely and are accessible only to the researcher. Researcher positioning (background and counter-measures) is discussed in Section 3.3.3, and the limitations of the interview format are revisited in Section 5.5.

3.5.1 Use of AI Assistants in the Preparation of the Thesis

A thesis whose object of study is the governance of generative AI use in organizations is obliged to be specific about the author's own use of generative AI in producing the manuscript. The disclosure that follows is structured to mirror, in miniature, the same contractual-versus-architectural distinction that the thesis develops for organizational deployment. It is included in the methodology rather than relegated to a back-matter statement because the choices made here are part of the research practice and bear on the credibility of the analytical work.

Within the writing process, generative AI assistants were used as a writing aid for rephrasing passages for clarity and concision, copy-editing for grammar and style, suggesting alternative section orderings, and reviewing draft prose against a target structure. The tools used in this capacity were

commercial cloud-hosted assistants accessed through their standard consumer or professional interfaces. AI assistants were also used as a coding aid when constructing the benchmark harness, principally for boilerplate, scaffolding, and documentation, with all logic reviewed and validated by the author before execution. The complete prompt template, schema description, query set, expected SQL, and scoring procedure are documented in Appendix B and were authored or verified by the author.

A second class of tasks was deliberately excluded from AI assistance. AI tools were not used to generate research findings, themes, or interpretive claims. Specifically, they were not used to code the interview notes, to construct the themes reported in Chapter 4, to generate the regulatory analysis, to fabricate or paraphrase practitioner statements, or to produce any numerical result reported in the benchmark. All citations were located, verified, and selected by the author; the bibliography was not populated by an AI assistant, and no reference appearing in this thesis was inserted without the author confirming that the cited work exists and supports the claim attached to it. Every quantitative result reported in Chapter 4 traces to a script and log file produced by the benchmark harness and recorded in the project repository.

To guard against the well-documented risk that generative models fabricate references or subtly distort source claims [52], three verification routines were applied. First, a source due-diligence pass was carried out across the bibliography in which each non-trivial citation was located through an independent search and the cited claim was checked against the original source. Second, AI-assisted rewrites of paragraphs were always compared to the prior draft, and edits that drifted from the author's argument were reverted. Third, no AI-generated text was incorporated without the author re-reading it for substantive accuracy in addition to style; the author takes full responsibility for any residual error.

This use is consistent with KTH's published considerations for studying with generative AI [53], which permit the use of AI tools as study and writing aids on the condition that the student remains responsible for the work, that essential intellectual contributions are the student's own, and that the use is transparent. The present disclosure is the transparency mechanism for this thesis.

The author's own choice of AI assistant is itself an instance of the deployment decision this thesis examines. The assistants used here are cloud-hosted services accessed through commercial APIs, and the data protection regime applied to their use is contractual: provider terms of service, retention policies, and no-training commitments where available. No content classified

by KTH as sensitive, no interview material that could identify a participant or an organization, no proprietary code under non-disclosure, and no personal data of others was entered into any AI assistant; the author's prompts contained only draft text written by the author and publicly available source material. This is the same contractual-control posture, scoped to a writing workflow rather than to enterprise analytics, that Chapter 2 characterizes for cloud API deployment, and the same conditions under which contractual control is treated as adequate in Chapter 5: low data sensitivity of the inputs, standard rather than strict regulatory exposure of the use case, and an explicit data-classification rule that excludes sensitive material from the channel. An architectural alternative, in which a self-hosted open-weight assistant would be used instead, was considered but judged disproportionate for the writing-aid use case given the inputs involved; the same calculation would change for a thesis or work product whose drafting involved sensitive interview transcripts or confidential client material, in which case the framework developed in this thesis would recommend the architectural-control path. The author's own deployment choice is therefore a worked example of the framework rather than an evasion of it.

Three residual risks remain. First, even with the verification routines above, AI-assisted writing can subtly homogenize prose and introduce hedged or generic language; the author has re-read the manuscript for this effect but it cannot be fully ruled out. Second, contractual protections rely on the provider honouring its commitments, which is the same trust-based posture that Chapter 2 identifies as the principal weakness of cloud API deployment. Third, the disclosure relies on the author's own honest reporting of tool use; no external audit was performed.

Chapter 4

Findings

This chapter presents the findings from the three research components. Section 4.1 reports the technical benchmarking results, establishing the performance baseline that contextualizes the deployment decision. Section 4.2 presents the themes that emerged from the organizational interviews. Section 4.3 presents the governance comparison across deployment architectures.

4.1 Technical Benchmarking

The benchmarking component compared GPT-5.1 (accessed through Azure OpenAI Service) and Qwen3-235B-A22B (served via vLLM on two NVIDIA A100 80GB GPUs) on 50 natural language to SQL queries against the NorthStar Retail schema, a synthetic enterprise database with 13 tables and approximately 2.5 million rows of seeded data. Each query was executed five times per model and the modal classification across runs was reported.

4.1.1 Accuracy

Table 4.1 summarizes execution accuracy by query difficulty level.

Table 4.1: Execution accuracy by query difficulty level.

Difficulty	**GPT-5.1**	**Qwen3-235B**
Simple ($n = 12$)	41.7%	66.7%
Moderate ($n = 16$)	12.5%	18.8%
Complex ($n = 12$)	0%	0%
Ambiguous ($n = 10$)	0%	0%
Overall ($n = 50$)	**14%**	**22%**

The self-hosted open-weight model produced more correct results than the proprietary cloud API model across all difficulty levels where either model succeeded; the absolute number of correct queries is small (11 versus 7 out of 50) and the difference is reported descriptively without statistical inference. Both models failed entirely on complex queries involving advanced window functions, recursive CTEs, and multi-level aggregation, and on deliberately ambiguous queries requiring business logic interpretation. These results are consistent with findings from the Spider 2.0 benchmark [21], where the best frontier model achieved 21.3% on real enterprise schemas.

Neither model produced a correct result on any of the 14 queries annotated as touching sensitive columns (customer names, personal identity numbers, salary data). As described in Chapter 3, this annotation concerns the columns targeted by the gold SQL; the prompts themselves contain only schema identifiers and the natural-language question, never data values. On the remaining 36 non-sensitive queries, GPT-5.1 achieved 18.0% accuracy and Qwen3-235B achieved 28.2%.

4.1.2 Error Analysis

Table 4.2 shows the distribution of error types across all 250 query executions per model (50 queries × 5 runs).

Table 4.2: Error distribution across 250 executions per model.

Classification	**GPT-5.1**	**Qwen3-235B**
Correct	37	55
Wrong columns	136	121
Wrong result	76	73
Syntax error	1	0
Runtime error	0	1

The dominant failure mode for both models was incorrect column selection: generating syntactically valid SQL that executes against the database but returns a result set whose columns differ from those of the gold reference query. This accounted for over half of all errors in both models. Wrong-result errors, where the SQL targets the correct columns but applies incorrect filtering, joining, or aggregation logic and therefore returns the wrong values or row set, were the second most common failure. Syntax errors and runtime errors were negligible. Neither model produced refusals.

The error counts in Table 4.2 are reported across all 250 executions per

model (50 queries × 5 runs), whereas the accuracy figures in Table 4.1 are reported per query after the modal classification is taken across runs. The two tables therefore measure related but distinct quantities: the per-execution error distribution captures the variability of model behaviour across repeated runs, while the per-query accuracy captures the stable, modal answer for each query.

The prevalence of column-selection errors suggests that the primary challenge is schema comprehension rather than SQL syntax generation. Both models can write valid SQL, but they struggle to correctly map natural language concepts to the appropriate columns in a 13-table schema with over 100 columns.

4.1.3 Latency

Table 4.3 reports latency statistics across all executions.

Table 4.3: Response latency in milliseconds.

Metric	GPT-5.1	Qwen3-235B
Mean	1217	1463
Median	1025	1199
P95	2129	3443
P99	3662	5412

GPT-5.1 was faster at all percentiles. The median response time for the cloud API was 1,025 ms versus 1,199 ms for the self-hosted configuration, a difference of approximately 15% relative to Qwen3-235B (or equivalently, the Qwen3 median is approximately 17% higher than the GPT-5.1 median). Both models delivered median latencies around one second, which is acceptable for interactive analytics use. The tail latency difference was more pronounced: the 99th percentile for GPT-5.1 was 3.7 seconds compared to 5.4 seconds for Qwen3-235B, reflecting the variability inherent in serving a large mixture-of-experts model on two GPUs.

4.1.4 Cost Structure

The two deployment architectures have fundamentally different cost structures. The cloud API model charges per token consumed. At the time of benchmarking, GPT-5.1 on Azure OpenAI Service was priced at $1.25 per million input tokens and $10.00 per million output tokens. Given the measured average token consumption of approximately 2,100 input and 110 output tokens per query, the unmodified per-query cost is given by Equation 4.1:

$$C_{\text{API}} = \frac{2{,}100 \times \$1.25 + 110 \times \$10.00}{10^6} \approx \$0.0037 \text{ per query.} \quad (4.1)$$

This is a purely variable cost: an organization that runs ten queries per day pays the same per-query rate as one that runs ten thousand.

A practical refinement is that Azure OpenAI offers *prompt caching*, which provides a discount on cached input tokens for repeated prompt prefixes above a minimum length. In this benchmark the database schema was sent as a fixed system prompt on every query and forms the dominant portion of the input. With cache hits applied to the schema-bearing portion of the prompt, the effective per-query cost would be lower than the unmodified rate quoted above. The unmodified figure is used in the analysis that follows because (i) it is conservative with respect to the central claim that the cloud API is dramatically cheaper than self-hosting at realistic volumes, (ii) the discount depends on a minimum number of cached tokens and a sufficiently warm prefix that may not always apply, and (iii) the comparative finding is robust to a 30–50% reduction in API cost: even at half the quoted rate, the self-hosted break-even moves higher, not lower.

The self-hosted configuration has a fixed cost structure. The two NVIDIA A100 80GB GPUs required to serve the Qwen3-235B-A22B model in INT4-W4A16 quantization cost approximately $3.40 each per hour on Azure ($6.80 per hour total for the instance), or approximately $4,896 per month if run continuously ($\$6.80 \times 24 \times 30$). This cost is incurred regardless of how many queries are processed. The per-query cost is therefore given by Equation 4.2:

$$C_{\text{self}}(n) = \frac{\$4{,}896}{30 \cdot n}, \quad (4.2)$$

where n is the daily query volume.

Table 4.4 reports per-query costs at representative volumes under continuous (24/7) GPU operation.

Setting Equation 4.2 equal to Equation 4.1 and solving for n gives a break-even volume of approximately $\$4{,}896/(30 \times \$0.0037) \approx 43{,}800$ queries per day, or roughly 1.3 million queries per month. Below this threshold, the self-hosted configuration is more expensive on a per-query basis, and the cost premium grows steeply at lower volumes: at 2,000 queries per day the self-hosted configuration costs approximately 22 times the cloud API equivalent. Figure 4.1 plots the per-query cost of the two configurations against daily query volume on logarithmic axes and shows the break-even point.

Table 4.4: Per-query cost comparison under continuous self-hosted GPU operation.

Daily volume	Self-hosted ($/query)	Cloud API ($/query)	Self-hosted premium
100	1.6320	0.0037	∼438×
1,000	0.1632	0.0037	∼44×
2,000	0.0816	0.0037	∼22×
10,000	0.0163	0.0037	∼4.4×
∼43,800	0.0037	0.0037	break-even

This estimate reflects only GPU compute costs under continuous operation. A realistic total cost of ownership would also include engineering and MLOps labour, monitoring and observability, security operations, model updates and redeployment effort, and the opportunity cost of underutilised capacity. Strategies such as autoscaling or scheduled (business-hours-only) operation can reduce the effective monthly cost, but typically introduce cold-start latency that conflicts with interactive analytics use. The break-even volume reported here should therefore be read as an optimistic lower bound for self-hosted competitiveness on cost alone.

A third architectural option is increasingly relevant but is not benchmarked in this thesis: serverless GPU platforms such as Modal, RunPod, Together AI, and Fireworks AI offer per-second or per-token billing for hosted open-weight models, including Qwen3 family models. These platforms occupy an intermediate position between cloud API and self-hosted: the organization does not operate the GPU but does select the model and avoid model-provider DPAs, while paying only for actual usage rather than reserved capacity. From a governance perspective they shift some control back to the consumer (model selection, prompt-only data flow) but reintroduce a managed-platform contractual relationship. They are mentioned here for completeness; their cost and governance positioning would refine the analysis but does not change the conclusion that 24/7 dedicated self-hosting carries a significant cost premium at typical analytics volumes.

The practical implication is that the cloud API is substantially cheaper for the vast majority of enterprise analytics workloads. Self-hosted deployment is cost-competitive only at very high sustained query volumes that few organizations would reach for analytical NL2SQL workflows. This cost asymmetry means that organizations choosing self-hosted deployment are typically accepting a substantial cost premium. As the interview findings in the following section confirm, they do so because governance and data control

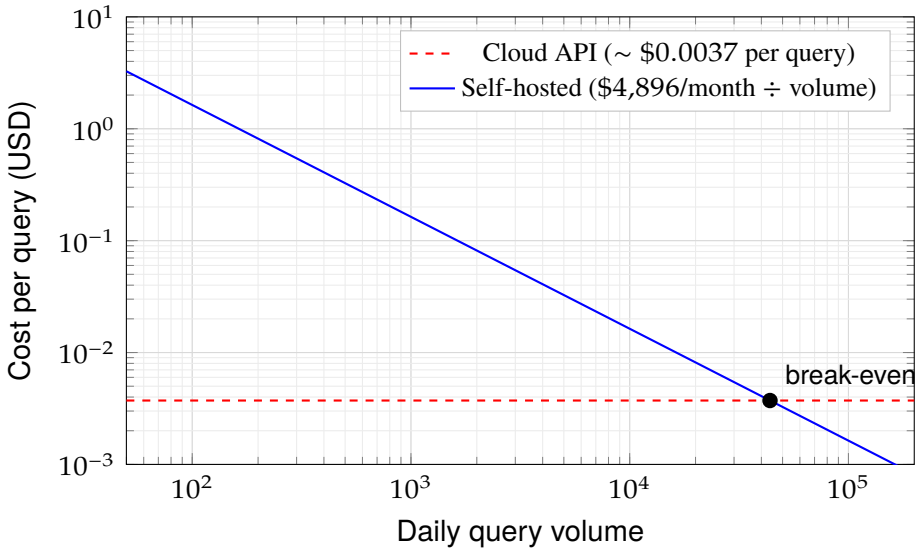


Figure 4.1: Per-query cost as a function of daily query volume, log-log scale. The cloud API cost is independent of volume; the self-hosted cost (24/7 GPU operation) declines with utilisation. The two curves meet at approximately 43,800 queries per day. At realistic enterprise analytics volumes (hundreds to a few thousand queries per day), the self-hosted configuration costs one to two orders of magnitude more per query than the cloud API.

requirements, not economics, drive the decision.

4.1.5 Summary of Benchmarking Findings

The benchmarking results establish three points relevant to the deployment decision. First, in this limited synthetic benchmark the self-hosted open-weight model did not show an observed accuracy disadvantage relative to the cloud API model; it produced more correct results on simple and moderate queries, although the absolute number of correct queries is small (11 versus 7 out of 50) and the difference is reported without statistical inference. Second, absolute accuracy is low for both models, especially on complex and ambiguous queries and on queries that touch sensitive columns, where neither model produced any correct result. This is consistent with the enterprise NL2SQL gap identified in the literature [20] and indicates that neither deployment architecture is currently sufficient for unsupervised enterprise NL2SQL on sensitive data without validation, guardrails, and human-in-the-loop review. Third, the cloud API is substantially cheaper than the self-hosted configuration at all workload volumes that the participating

organizations described as plausible and offers somewhat faster response times. The architectural choice between cloud API and self-hosted deployment is therefore not the primary differentiator of NL2SQL accuracy in this benchmark; it is a governance and capability choice taken in the presence of low absolute model performance, and the governance and organizational factors examined in the following sections explain how organizations resolve that choice.

4.2 Interview Findings

Thirteen semi-structured interviews were conducted with practitioners across a range of organizational contexts, including pharmaceutical, healthcare, financial services, insurance, fintech, forestry and industrial, data analytics, performing arts, voice technology, and research institutions. Participants held roles ranging from product management and engineering leadership to risk analysis, data science, and AI team leadership. The interviews explored how each organization reasons about LLM deployment for analytics on sensitive data, what factors shape their preferred deployment model, and what barriers and enablers they encounter. Each participant is assigned an anonymized identifier (P1–P13) used throughout the analysis. Table 4.5 summarizes the interview sample.

The thematic analysis identified four main themes, organized below along the three TOE contexts and a cross-cutting theme on the deployment decision itself. Table 4.6 maps which participants contributed evidence to each theme, providing an audit trail from the codebook (Section 3.3.3) to the analytical narrative below. A check mark indicates that the participant's account contained at least one coded segment supporting the theme.

4.2.1 Technological Context: Capability Is Assumed, Not Evaluated

A consistent finding across interviews was that practitioners spend relatively little time evaluating the technical capability of models when making deployment decisions. Most participants had used cloud-based LLM tools (predominantly ChatGPT, Copilot, or Gemini) and assumed that both proprietary and open-source models could handle the analytics tasks they had in mind. P3 (technology, AI-native) reported 95% AI adoption across the company and considered model capability largely settled, focusing instead

Table 4.5: Interview participant profiles. Sensitivity, regulation, capability and observed regulatory salience were coded from interview accounts using the scheme described in Section 3.3.3. "Regulation" reflects formal legal and sector-specific exposure; "salience" reflects whether regulatory requirements were built into the participant's account of technology decision-making. Preferred deployment reflects the participant's stated or implied preference at the time of the interview.

ID	Industry	Sens.	Regulation	Salience	Capability	Preferred
P1	Pharmaceutical	High	Strict	High	High	Self-hosted
P2	Healthcare services	High	Strict	High	Med-High	Self-hosted
P3	Technology (AI)	Medium	Standard	Low	High	Managed
P4	Data analytics	Medium	Standard	Low	Medium	Managed
P5	Technology (CRM)	Medium	Standard	Low	Medium	Managed
P6	Financial services	High	Strict	High	Med-High	Self-hosted
P7	Fintech	High	Strict	Low	Medium	Managed
P8	Forestry/Industrial	Medium	Standard	Low	Medium	Managed
P9	Insurance	High	Strict	Low	Med-High	Managed
P10	Performing arts	Medium	Standard	Low	Low	Managed
P11	Technology (events)	Low	Standard	Low	High	Managed
P12	Research institution	Medium	Standard	Low	Low	Managed
P13	Voice technology	High	Standard	Low	Medium	Managed

Sens. = data sensitivity. "Managed" = managed cloud API service.

on data governance as the "core challenge for enterprise adoption." P9 (insurance) described routinely using Claude and ChatGPT for ad hoc analytics across multiple data sources without evaluating model differences. P7 (fintech) had already integrated Gemini into BigQuery workflows and was interested in whether alternative platforms could "scan through the whole BigQuery and different files, and kind of structure them properly," framing the question as one of data integration capability rather than model quality.

Where technical concerns did arise, they related to deployment infrastructure and tool reliability rather than model accuracy. P12 (research institution) described the operational complexity of running self-hosted models as prohibitive given the university's constrained IT capacity and ongoing building relocation. P10 (performing arts) had evaluated Julius AI for a large data analysis project and abandoned it not because of model capability but because of stability failures on datasets exceeding one million records, inconsistent results across repeated runs, and the inability to combine database and spreadsheet sources in a single analysis. P6 (financial services) described a prudent approach to technology adoption: "We don't want to just put in

Table 4.6: Theme-to-participant matrix. A bullet (•) indicates that the participant's interview account contained at least one coded segment supporting the theme. The four themes are: **T1** Capability is assumed, not evaluated; **T2** Capability and cost as gatekeepers; **T3** Regulation as the decisive factor; **T4** The deployment decision as a governance threshold. Themes T1 and T3 differentiate among participants; T2 and T4 are framework-level themes that organize all thirteen accounts (every account contains some statement about capability or cost gatekeeping, and every account positions the organization somewhere on the governance threshold).

Participant	**T1**	**T2**	**T3**	**T4**
P1 (Pharmaceutical)	•	•	•	•
P2 (Healthcare)	•	•	•	•
P3 (Technology, AI)	•	•		•
P4 (Data analytics)	•	•	•	•
P5 (Technology, CRM)		•	•	•
P6 (Financial services)	•	•	•	•
P7 (Fintech)	•	•	•	•
P8 (Forestry/Industrial)	•	•		•
P9 (Insurance)	•	•	•	•
P10 (Performing arts)	•	•		•
P11 (Technology, events)		•		•
P12 (Research institution)		•		•
P13 (Voice technology)		•	•	•

anything. We're just studying all the different technologies that exist. And if we make any [decision], it will definitely be with the security and everything in mind." The evaluation was not about whether the technology works but about whether it can be deployed safely. This finding aligns with Hughes et al. [7], who found that perceived complexity is a significant barrier to generative AI adoption, moderated by organizational change capacity.

4.2.2 Organizational Context: Capability and Cost as Gatekeepers

The organizational context revealed three distinct patterns depending on the organization's operational capability and resource constraints.

Organizations with low operational capability treated cost and convenience as the binding constraints. P12 (research institution) operated under a tight budget and described the price of enterprise managed services as "a kind of

a blocker," noting that bureaucratic approval processes and unclear decision authority further complicated procurement: "Sometimes it really takes a long time to get things done when you work in a public organization." P10 (performing arts) had lost the company's only data engineer mid-project, forcing a switch to AI tools out of necessity. With a staff unable to maintain infrastructure, self-hosted deployment was not a realistic option regardless of governance preferences. For these organizations, the deployment question was straightforward: they would use whichever managed service was affordable and required no operational investment.

Organizations with medium operational capability showed a different pattern, where the deployment model mattered less than the completeness of the analytics offering. P7 (fintech) had an analyst on the team but sought self-service analytics "without any knowledge of SQL or any other language or tools," evaluating managed platforms primarily on their ability to unify data sources. P4 (data analytics) required data processing agreements and security audit compliance but was oriented toward managed services with contractual protections. P8 (forestry and industrial) emphasized column-level permissions and access control (governance at the data access layer) but sought a managed platform for implementation speed. P5 (technology, CRM) experienced data retention challenges within existing Microsoft partnerships, illustrating how governance friction can arise even within cloud ecosystems.

Organizations with high operational capability occupied two poles. P3 (technology, AI-native) had built internal agent systems with 95% adoption, deployed proactive monitoring workflows, and noted that "LLMs as classifiers work well but [are] cost-intensive at scale." Despite high capability, the organization preferred managed cloud services and federated query architectures over self-hosting, because their governance concerns centered on data quality and semantic consistency rather than regulatory compliance. By contrast, P1 (pharmaceutical) and P2 (healthcare) possessed substantial technical sophistication (P1 ran Monte Carlo simulations with 10,000+ iterations on sensitive financial data, and P2 managed a 350-employee organization across four divisions) but directed that capability toward self-hosted or sandboxed deployment specifically to satisfy regulatory requirements. P2 had already deployed Claude on a self-managed virtual machine in Finland, a deliberate choice of European data residency.

4.2.3 Environmental Context: Regulation as the Decisive Factor

The environmental context, and specifically the organizational salience of regulatory pressure, emerged as the single strongest determinant of the deployment decision. Three distinct regulatory postures were observed across the thirteen interviews.

Organizations where regulation was operationally salient required self-hosted or sandboxed deployment without exception. P1 (pharmaceutical) described strict requirements for sandbox environments and stated that the organization had "limited ability to use external AI services" due to the sensitivity of financial modeling data for drug portfolio decisions. P2 (healthcare) was actively preparing for a SOC 2 certification audit, a US auditing framework for service organizations covering security, availability, confidentiality, and related criteria that is distinct from European data protection regulation but commonly required by enterprise customers, and had already deployed language model infrastructure on a virtual machine in a European jurisdiction, treating geographic data placement as part of a broader posture of demonstrating control over where sensitive data is processed. P6 (financial services) described the organization's approach as fundamentally shaped by risk management, characterising the work as one of continuous risk assessment in which any operational risk arising from AI tooling has to be evaluated and addressed before adoption. For these organizations, the deployment decision was not a preference but a regulatory constraint.

A second group of participants operated in industries subject to strict regulation but did not describe regulation as a binding constraint on their deployment choices. P7 (fintech) had signed extensive data protection agreements and acknowledged strict privacy obligations, yet accepted a managed cloud service after reviewing its contractual protections, including EU-based encrypted storage and zero data retention policies. P9 (insurance), whose previous organization processed over 100,000 claims per year across multiple jurisdictions, described using cloud-based LLMs for analytics without raising compliance concerns. P4 (data analytics) required data processing agreements and a security audit but was oriented toward managed services rather than self-hosting. These participants suggest that the existence of regulation alone does not determine deployment choice; rather, it is the degree to which regulatory requirements are organizationally salient (embedded in daily practice and decision-making) that activates the demand for architectural control.

Organizations operating under standard baseline regulation (notably GDPR for European organizations) without strong sector-specific regimes expressed no governance concerns about managed cloud services in their accounts. P10 (performing arts) handled patron and donor data across jurisdictions but did not mention data protection at any point, with every decision driven by operational necessity; this is consistent with low salience even though GDPR formally applies. P11 (technology, events) focused on AI agent governance, citing the need for "guardrails essential for high-impact decisions," but framed this as a product design challenge rather than a regulatory obligation. P12 (research institution) was concerned exclusively with cost and procurement, not data protection. P13 (voice technology) explicitly acknowledged "privacy and security considerations for voice data" (a particularly sensitive data category) and had built deployment flexibility (cloud, on-premise, and edge) as a market differentiator, but this reflected customer-facing product positioning rather than the organization's own internal compliance enforcement. In all four cases, baseline GDPR exposure was present, but the regulatory salience indicators in Section 3.3.3 were not exhibited in the interview accounts.

4.2.4 The Deployment Decision: A Governance Threshold

Across the thirteen interviews, a clear but nuanced pattern emerged. The deployment decision operates as a threshold function, but the threshold is activated not by data sensitivity or regulatory exposure alone, but by the organizational salience of regulation: the degree to which compliance requirements are embedded in daily practice and shape technology decisions.

The thirteen accounts cluster into three positions on this threshold. Organizations below it (those without strict sector-specific regulation, or those where regulatory requirements were not operationally salient) consistently preferred managed cloud services. Their reasoning centered on cost and operational convenience (P10, P12), technical capability and speed (P3, P8), or satisfaction with contractual protections (P4, P5, P7). For these organizations, data processing agreements, encryption, and regional hosting guarantees were sufficient assurance.

Organizations above the threshold (those where regulatory requirements were operationally salient, with at least two of the indicators in Section 3.3.3 exhibited spontaneously in the interview) required self-hosted or sandboxed deployment. P1 (pharmaceutical) reported procurement-level restrictions on

external AI services and mandated sandbox environments. P2 (healthcare) described an active SOC 2 process and had already placed infrastructure in a specific European jurisdiction as a compliance act. P6 (financial services) explicitly framed any technology evaluation as a risk assessment exercise involving operational risk review. In all three cases, multiple salience indicators (procurement gates, audit/certification processes, mandatory risk review) appeared in a single account, and deployment was framed not as a preference but as a non-negotiable requirement.

A gray zone emerged among organizations with high data sensitivity and formal sector-specific regulation that nonetheless accepted managed cloud services. P7 (fintech) operated under strict data protection agreements but found contractual safeguards sufficient and did not describe procurement gates or DPIA processes for the AI deployment specifically. P9 (insurance) processed highly sensitive claims data across jurisdictions but used cloud LLMs without raising compliance review, audit, or restriction signals in the interview. The salience indicators were not exhibited despite the formal regulatory exposure being unambiguous. Two interpretations are consistent with the data: either the organization has accepted a deliberate risk based on contractual due diligence (compatible with the "low salience" coding) or the participant did not have visibility into compliance processes that exist elsewhere in the organization (a limitation of the indicator-based coding noted in Section 3.3.3). The thesis treats the gray zone as a hypothesis-generating observation rather than as a robust pattern, given that it rests on two cases.

The threshold itself is therefore best understood as a combination of formal regulatory exposure and the operational salience of that regulation in technology decisions. Strict sector-specific regulation that is salient in daily practice (P1, P2, P6) universally drove architectural control. Strict regulation that was not salient in the interview accounts (P7, P9) coexisted with managed-service acceptance. Baseline regulation without operational salience (P3, P4, P5, P8, P10, P11, P12, P13) likewise coexisted with managed-service acceptance. This refines the finding: it is not the regulatory environment alone but the organizational internalization of regulatory requirements that, in this sample, accompanied the demand for self-hosted deployment.

Cost played a secondary role for organizations above the threshold. P1, P2, and P6 did not frame their deployment decisions in cost terms; governance requirements were treated as non-negotiable investments. Below the threshold, cost was often the primary consideration: P12 described the price of enterprise managed services as the main barrier, and P10's technology choices were driven entirely by what the organization could operationally

sustain after losing its only data engineer.

4.3 Governance Comparison

This section compares the governance properties of the two benchmarked deployment architectures, drawing on regulatory analysis, provider documentation, and findings from the interviews. The comparison is structured around six dimensions that practitioners identified as relevant to their deployment decisions.

4.3.1 Data Residency and International Transfer

In the cloud API configuration, prompts containing database schema information and natural language queries are transmitted to the cloud platform operator's infrastructure for processing. Azure OpenAI Service offers regional deployment options, including EU-based endpoints, which can address data residency requirements within the European Economic Area. According to Microsoft's documentation, prompts and completions submitted through Azure OpenAI are not made available to the upstream model provider (OpenAI) and are not used for training without the customer's explicit consent; the contractual relationship for inference-time data is therefore primarily with Microsoft as the cloud platform operator. However, Microsoft is itself a US-headquartered company, and the legal exposure to US jurisdiction, particularly under the CLOUD Act, remains a concern regardless of where the data is physically processed. The EU-US Data Privacy Framework provides a current legal basis for such transfers, but its durability is uncertain given the history of predecessor frameworks being invalidated by the Court of Justice of the European Union.

In the self-hosted configuration, prompt content does not leave the organization's cloud tenancy and is not transmitted to a separate managed LLM API provider. There is no international transfer through an LLM-specific provider, and the LLM-layer subprocessor chain is reduced to the infrastructure provider. The cloud infrastructure provider (AWS, Azure, or GCP) operates the underlying compute workload but does not access prompt content, and the relationship is governed by a standard infrastructure DPA rather than an AI-specific processing agreement. Where the cloud infrastructure provider's headquarters or support operations sit in a third country, EDPB guidance on remote access [14] still applies, so the

configuration reduces but does not necessarily eliminate exposure to third-country jurisdiction.

4.3.2 Data Processing Agreements and Subprocessor Chains

The cloud API configuration requires a data processing agreement with the cloud platform operator under GDPR Article 28. Enterprise managed service platforms such as Azure OpenAI Service provide such agreements, which typically include no-training commitments, data retention limits, and regional processing guarantees. The subprocessor chain may include the platform operator, any underlying model provider acting as a subprocessor, and infrastructure subcontractors; the controller must assess each link, including how the contractual chain handles data when the upstream model provider is contractually walled off from inference data, as is the case for OpenAI under Azure OpenAI's terms.

The self-hosted configuration does not require a separate model-provider DPA covering inference data, because no managed LLM API provider receives prompt content. The DPA chain at the LLM layer reduces to the infrastructure provider relationship for the compute layer, which is a well-established and widely audited relationship. The subprocessor chain at the LLM layer is shorter and more transparent, although the underlying infrastructure DPA still applies and may itself involve subcontractors for support, monitoring, or regional capacity.

4.3.3 Auditability and Logging

Both configurations support logging of prompts, responses, and metadata. In the cloud API configuration, the managed service platform provides logging through its standard monitoring tools, and the organization can capture requests and responses on its side. However, the organization cannot independently verify what happens to the data within the provider's infrastructure between receipt and response.

In the self-hosted configuration, the organization controls the entire logging pipeline. Every prompt, response, and intermediate computation occurs within infrastructure the organization administers. This provides complete audit trail visibility, which several interview participants in regulated sectors identified as a requirement for their compliance frameworks.

4.3.4 Data Lifecycle Control

In the cloud API configuration, data retention and deletion are governed by the provider's policies and the terms of the DPA. Azure OpenAI Service commits to not retaining prompt data beyond a short processing window and provides a zero-retention option. Exercising GDPR rights such as the right to erasure requires cooperation from the provider, mediated by the contractual framework.

In the self-hosted configuration, the organization has direct control over the data lifecycle. Data can be deleted immediately after processing, retained according to internal policies, or handled in whatever manner the organization's governance framework requires, without depending on a third party's cooperation or infrastructure.

4.3.5 Contractual Versus Architectural Guarantees

This dimension captures the central distinction of the thesis. Table 4.7 summarizes the governance properties across the two architectures.

Table 4.7: Governance comparison across deployment architectures.

Dimension	**Cloud API**	**Self-Hosted**
Data residency	Provider-determined; EU options available	Organization-controlled
International transfer	Subject to DPF; CLOUD Act exposure	No transfer
DPA requirement	Required with model provider	Infrastructure DPA only
Subprocessor chain	Multi-layer (platform, model provider, infra)	Single layer (infra provider)
Audit trail	Partial; provider-side opaque	Complete; organization-controlled
Data lifecycle	Provider-mediated deletion	Direct organizational control
Control mechanism	Contractual (DPA, SLA, no-training clause)	Architectural (network isolation)

The cloud API configuration relies on contractual instruments to protect data: DPAs, service-level agreements, no-training commitments, and regional processing guarantees. These are meaningful protections that satisfy the compliance requirements of many organizations. However, they are ultimately trust-based. The organization trusts that the provider honors its commitments, that the provider's infrastructure is secure, and that the

provider's subprocessors comply with the same obligations. The EDPB's post-Schrems II guidance explicitly notes that contractual mechanisms "do not bind governmental authorities" [14], which limits their effectiveness against state-level access requests.

The self-hosted configuration provides architectural protection at the LLM-specific layer: prompt content is not transmitted to a separate managed LLM API provider, and the guarantee at this layer does not depend on a model-provider contract being honored. The cloud infrastructure provider remains in the processing environment, so the strength of architectural control is conditional on the tenant configuration, access controls, encryption, logging, and contractual terms with the infrastructure provider; in the absence of those operational controls, an organization may achieve less effective governance through a poorly configured self-hosted deployment than through a well-governed managed service. The trade-off is that the organization assumes full responsibility for securing the infrastructure, maintaining the model serving stack, and managing the operational overhead. As the interview findings confirm, this trade-off is accepted by organizations for which regulatory requirements make contractual controls insufficient, and avoided by organizations for which the operational burden outweighs the marginal governance benefit relative to a contractually robust managed service.

Chapter 5

Discussion

This chapter integrates the findings from the three research components (technical benchmarking, organizational interviews, and governance analysis) through the TOE framework. It positions the results against prior work, develops the conceptual contribution of contractual versus architectural data control, examines what "open source" means for deployment decisions in practice, and discusses implications for organizations navigating the deployment choice. The chapter concludes with a discussion of the study's limitations.

5.1 Integrating Findings Through the TOE Framework

The TOE framework identifies three contexts that shape technology decisions: the technological context (characteristics of the technology itself), the organizational context (internal factors such as capability, cost, and management support), and the environmental context (external pressures including regulation, competition, and industry norms) [16]. This thesis extends the framework from binary adoption decisions to the specific question of deployment mode: given that an organization has decided to use LLMs for analytics, what determines whether it deploys via a cloud API or through self-hosted infrastructure? The three research components map onto the three TOE contexts, and their integration reveals how each context contributes to the deployment decision.

5.1.1 Technological Context: Architecture Is Not the Differentiator

The benchmarking results show that the deployment architecture is not the dominant performance factor in this NL2SQL setting. The self-hosted open-weight model (Qwen3-235B in INT4 quantization) produced 22% execution accuracy versus 14% for the proprietary cloud API model (GPT-5.1) on the 50-query benchmark. The absolute number of correct queries is small (11 versus 7), the difference is reported without statistical inference, and both models failed entirely on complex queries, ambiguous queries, and queries touching sensitive columns. The dominant failure mode for both was incorrect column selection, a schema comprehension challenge that is independent of deployment architecture.

The interpretation of this result requires care. It does not establish that organizations choosing self-hosted deployment incur no technical cost: the absolute performance is too low for either architecture to be considered reliable for unsupervised analytics on sensitive data. It also does not establish that proprietary frontier models are technically inferior: the gap is small, the benchmark is narrow, and one model pair on one synthetic schema cannot generalize to architectural superiority. What the result does establish is that, at present, architectural choice is not the most consequential lever for analytical accuracy. Both architectures fail in similar ways on hard queries, and both succeed in similar ways on easy queries.

A striking tension emerges between this benchmark finding and the interview accounts. Practitioners across the sample treated model capability as effectively settled, spending little time evaluating accuracy. P3 (technology, AI-native) had achieved 95% AI adoption and treated model capability as a solved problem. P7 (fintech) framed evaluation in terms of data integration capability, not model quality. P9 (insurance) used multiple cloud LLMs interchangeably for analytics without comparing their outputs systematically. P6 (financial services) described studying technologies carefully but evaluating them through a security lens, not a capability lens. Yet the benchmark suggests that capability is not in fact solved: neither model would deliver acceptable accuracy on a realistic enterprise NL2SQL workload without substantial validation, guardrails, or human-in-the-loop review. Organizations are therefore making deployment decisions that assume a level of technical capability that the empirical evidence does not yet support. This gap between assumed and observed capability is itself a finding, and it suggests that governance, capability building, and human oversight should be

central to deployment decisions even after the architectural choice has been made.

This pattern is consistent with von Schwerin and Reichert [1], who reported comparable performance between open-source and proprietary models on GDPR compliance documentation, and with Floratou et al. [20], who documented severe accuracy degradation on enterprise NL2SQL tasks. Together with the present results, these findings support a more measured framing of the technological context: architectural choice is not the primary determinant of accuracy, but accuracy itself is not yet at a level where any architecture can be deployed unsupervised on sensitive enterprise analytics. The deployment decision is therefore determined by the organizational and environmental contexts, while task-level validation remains a distinct and unresolved problem.

5.1.2 Organizational Context: Capability as Enabler, Not Determinant

The organizational context shapes the deployment decision primarily by determining what is feasible rather than what is preferred. Three capability tiers were observed.

Organizations with low operational capability defaulted to managed cloud services regardless of other considerations. P12 (research institution) faced budget constraints, bureaucratic procurement processes, and unclear decision authority: "Sometimes it really takes a long time to get things done when you work in a public organization." P10 (performing arts) had lost the company's only data engineer mid-project, making self-hosted deployment operationally impossible. For these organizations, the deployment "decision" was not a decision at all; it was a constraint. This finding is consistent with Hughes et al. [7], who found that organizational change capacity moderates the relationship between perceived complexity and adoption. In our data, organizations with low change capacity do not weigh deployment trade-offs; they take the only option available to them.

Organizations with high operational capability could self-host but did not uniformly choose to do so. P3 (technology, AI-native) had built sophisticated internal agent systems with proactive monitoring workflows, yet preferred managed cloud services with federated query architectures because governance concerns centered on data quality rather than regulatory compliance. P1 (pharmaceutical) and P2 (healthcare), with comparable or greater technical sophistication, directed that capability toward self-

hosted deployment specifically because regulatory requirements demanded it. This divergence is the key organizational finding: capability enables the deployment choice but does not determine it. What determines the choice is the environmental context.

Cost exhibited a similar pattern. Below the governance threshold, cost was often the primary consideration: P12 described the price of enterprise managed services as the main barrier, and P10's choices were constrained by what the organization could sustain. Above the threshold, cost was secondary: P1, P2, and P6 did not frame deployment decisions in cost terms. The benchmarking cost analysis reinforces this pattern: the cloud API is substantially cheaper for most workloads, but organizations above the governance threshold accept the cost premium of self-hosting because governance, not economics, drives their choice.

5.1.3 Environmental Context: Regulatory Salience as the Threshold

The environmental context emerged as the decisive factor. However, the interview data reveals a more nuanced mechanism than prior TOE studies have captured. The deployment decision is not driven by the existence of regulation or by data sensitivity alone, but by the *organizational salience* of regulation: the degree to which regulatory requirements are embedded in daily practice, enforced by compliance functions, and visible in technology procurement decisions.

Three regulatory postures were observed across the thirteen interviews:

1. **Regulation operationally salient** (P1, P2, P6): These organizations described regulatory requirements as non-negotiable constraints that dictated deployment architecture. P1 (pharmaceutical) required sandbox environments and had "limited ability to use external AI services." P2 (healthcare) had deployed inference infrastructure in a specific European jurisdiction in preparation for SOC 2 certification. P6 (financial services) described security evaluation as a professional obligation, framing the organization's posture as one of continuous risk assessment that necessarily extends to any operational risk arising from AI. For these participants, the deployment decision was not a trade-off but a compliance requirement.

2. **Regulation present but not salient** (P7, P9): These organizations operated in regulated industries with high data sensitivity but did

not describe regulation as a binding constraint on their deployment choices. P7 (fintech) had signed extensive data protection agreements but accepted a managed cloud service after reviewing its contractual protections. P9 (insurance), whose previous organization processed over 100,000 claims per year across multiple jurisdictions, described using cloud-based LLMs without raising compliance concerns. In these cases, regulation existed as a formal requirement but had not been internalized into technology decision-making workflows.

3. **Standard regulation, no operational salience** (P3, P4, P5, P8, P10, P11, P12, P13): These organizations expressed no governance concerns about cloud services in their accounts, even though baseline GDPR exposure formally applies to several of them. P10 (performing arts) processed US patron and donor data on a Danish platform, a US-to-EU dataflow that places GDPR obligations on the controller, without mentioning data protection. P11 (technology, events) discussed AI governance in terms of product design guardrails rather than regulatory compliance. P12 (research institution) was concerned exclusively with cost and procurement. P13 (voice technology) acknowledged the sensitivity of voice biometric data but framed deployment flexibility as a market differentiator rather than as an internal compliance requirement.

This three-zone pattern refines the existing literature. Hughes et al. [7] identified privacy and regulatory concerns as drivers of AI adoption decisions, but treated them as continuous variables in a structural equation model. The interview data suggests that regulatory influence on deployment operates not as a continuous variable but as a threshold function moderated by organizational internalization. The critical distinction is not between "regulated" and "unregulated" organizations, but between organizations where regulation has been internalized into technology decision-making and organizations where it remains a formal requirement disconnected from day-to-day practice. This internalization dimension, which we term regulatory salience, determines whether the governance threshold is activated.

A consequence of this finding is that, in this sample, data sensitivity does relatively little independent work as an explanatory variable. P13 (voice technology) processes biometric voice data (a special-category data type under the GDPR) but falls below the governance threshold because the organization's internal compliance functions did not exhibit the salience indicators in the interview account. P9 (insurance) processes claims data across multiple jurisdictions but likewise falls below the threshold.

Conversely, P1 (pharmaceutical) and P6 (financial services) handle sensitive data, but it is the operational embedding of compliance functions, not the sensitivity classification itself, that puts them above the threshold. Standard TOE applications treat data sensitivity as an environmental factor in its own right; the present data suggest that sensitivity is best read as a condition that increases the likelihood of regulatory salience developing inside the organization, rather than as a direct driver of the deployment choice. This is an empirical observation specific to the present sample, and one of the patterns that a larger and more deliberately stratified sample (Section 6.3) would be best placed to test. Figure 5.1 summarizes the proposed model.

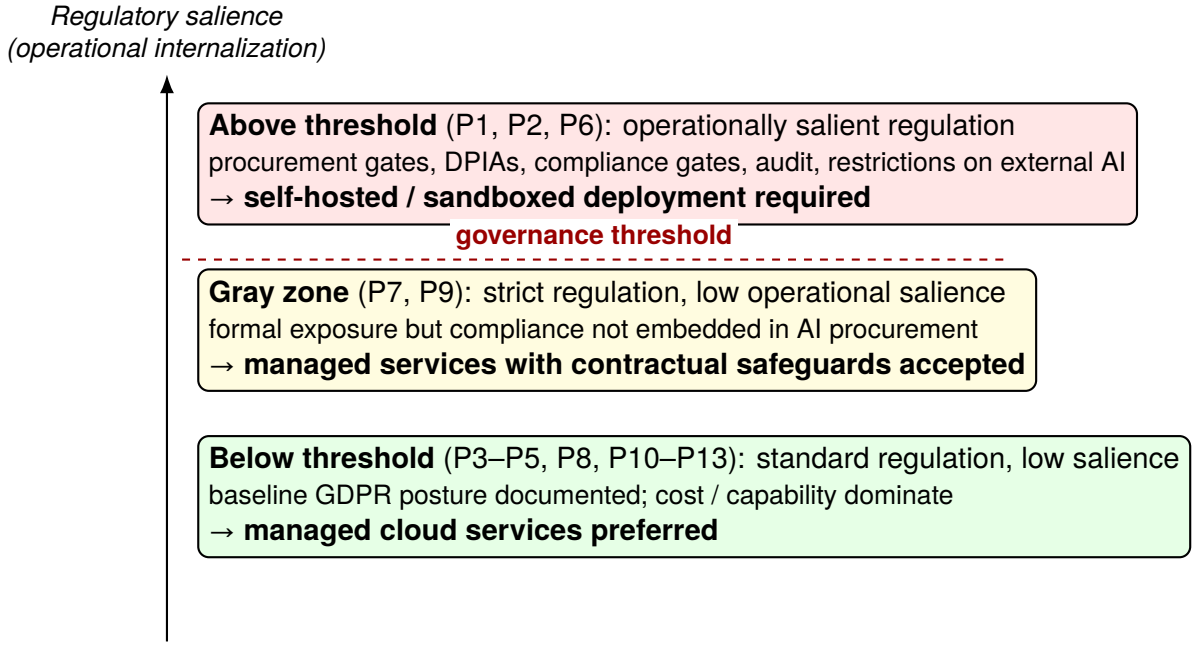


Figure 5.1: Governance threshold model. Participant identifiers (P1–P13) refer to the interview sample profiled in Table 4.5. The deployment decision is moderated by regulatory salience (the operational internalization of regulatory requirements) rather than by the existence of regulation alone. Strictly regulated organizations whose compliance functions are embedded in AI procurement (above threshold) require architectural control; strictly regulated organizations whose compliance is formal but not operationally enforced (gray zone) accept contractual control; organizations under baseline regulation without operational salience default to managed services driven by cost and capability.

5.2 Contractual Versus Architectural Control

The governance comparison and interview findings together sharpen the central conceptual distinction of this thesis: between contractual and architectural mechanisms for data control.

In the cloud API configuration, data protection rests on contractual instruments. Data processing agreements, zero-retention policies, regional hosting guarantees, and no-training commitments create a layered set of protections that are legally binding and, for many organizations, sufficient. P7 (fintech) accepted managed cloud services after reviewing these protections. P4 (data analytics) required data processing agreements and security audit compliance as preconditions. These participants treated contractual controls as credible and adequate for their governance requirements. P5 (technology, CRM) illustrated a related but distinct pattern: the organization remained within a managed cloud ecosystem but encountered ongoing friction over data retention terms with its platform vendor, indicating that contractual control is not always frictionless even when it is accepted.

In the self-hosted configuration, data protection at the LLM-specific layer is architectural. Prompt content is not transmitted to a separate managed LLM API provider, and the guarantee at this layer follows from the deployment topology itself rather than from a contract being honored. The cloud infrastructure provider remains part of the processing environment, and the strength of architectural control therefore depends on the tenant configuration, access controls, logging, encryption, and the contractual terms governing the infrastructure layer; architectural control reduces the LLM-provider exposure rather than eliminating all third-party exposure. P2 (healthcare) had deployed on a European virtual machine specifically to ensure data residency. P1 (pharmaceutical) required sandbox environments as a structural constraint. P6 (financial services) described evaluating any new technology "with the security and everything in mind" as an organizational default.

The distinction between contractual and architectural control provides a vocabulary for describing what the environmental context in the TOE framework actually translates into in this domain. It is not regulation by itself that determines the deployment choice, but whether the organization's governance requirements can be satisfied by contractual mechanisms or whether they require architectural guarantees. This framing extends two established concepts to the enterprise deployment setting. Lessig's [34]

argument that "code" (architecture) is a regulatory modality distinct from law and contract was developed for public-facing internet architecture rather than enterprise infrastructure choice; the present thesis applies the broader principle, that design choices constrain behaviour in ways that contracts cannot fully replicate, to a more specific organizational decision. The principle of Privacy by Design embedded in GDPR Article 25 calls for data protection to be built into the technical design of systems rather than bolted on through policy, which the contractual-versus-architectural distinction applies to the LLM deployment case.

The EDPB's post-Schrems II guidance reinforces this distinction. The guidance explicitly notes that contractual mechanisms "do not bind governmental authorities" [14], which means that contractual protections against third-country access are inherently limited. For organizations above the governance threshold, this limitation is decisive: the concern is not whether the provider will honor its commitments, but whether the data should cross the organizational perimeter at all. Architectural control eliminates this concern by design.

P13 (voice technology) offered a provider perspective on this dynamic. The company had built deployment flexibility (cloud, on-premise, and edge) as a market differentiator, explicitly because customers demanded privacy control over voice data. This suggests that the contractual-versus-architectural distinction is not merely an analytical framework but a market reality that shapes product architecture decisions.

5.3 The Meaning of "Open Source" for Deployment Decisions

Liesenfeld and Dingemanse [13] demonstrated that "open source" in generative AI is "necessarily composite and gradient," with most models falling far short of the transparency implied by the label. Their 14-dimension openness framework revealed that many prominently marketed "open-source" models are at best open-weight: the model parameters are available, but the training data, training code, and evaluation methodology are not.

The interview data suggests that practitioners largely bypass this complexity. None of the thirteen participants engaged with the granularity of openness that Liesenfeld and Dingemanse document. For practitioners making deployment decisions, "open source" functioned as a proxy for a single capability: *can we run it ourselves?* The relevant distinction was not

between truly open and open-weight models, but between models that can be deployed within the organization's infrastructure and models that can only be accessed through an external API. P13 (voice technology) described open source as a market differentiator and trust mechanism, but the trust derived from deployment flexibility rather than from training data transparency.

This finding has two implications. First, it suggests that the governance benefits of self-hosted deployment do not depend on the model being "truly" open-source in the sense that Liesenfeld and Dingemanse define. An open-weight model that can be served on the organization's own GPUs provides the same architectural data control as a model with full training data transparency. The governance advantage is in the deployment topology, not in the model's provenance. Second, it highlights a gap between academic analysis of openness and practitioner reasoning: the dimensions of openness that concern researchers (training data, evaluation methodology, licensing terms) are largely invisible in organizational deployment decisions. This gap represents both a practical efficiency (organizations get the governance benefit they need without engaging in complex openness assessments) and a potential risk, as Liesenfeld and Dingemanse warn, if the "open-source" label is used to justify regulatory exemptions that the actual level of openness does not support.

5.4 Implications for Industrial Management Practice

The findings have implications that go beyond the technical choice between two model-serving architectures. Read through an industrial management lens, the deployment decision is best understood as a structured combination of make-or-buy strategy, vendor-dependence management, capability building, and risk governance, all conditioned by the organization's regulatory operating model.

5.4.1 Make-or-buy and vendor dependence

The cloud API versus self-hosted choice is, in this context, a make-or-buy decision applied to inference infrastructure. Buying (cloud API) offers fast time to value, no fixed cost, and a contractual relationship with a credible counterparty, at the cost of vendor concentration on a small number of frontier model providers and platform operators. Making (self-hosted open-weight) requires upfront capability investment but reduces concentration

risk, increases optionality (the organization can change models without changing the deployment topology), and shifts the governance posture from contract enforcement to architectural control. The benchmarking and cost analyses in this thesis show that the trade-off is no longer primarily about technical performance: open-weight models are competitive on accuracy, but managed cloud services are dramatically cheaper at the volumes most enterprise analytics workloads reach. Make-or-buy therefore reduces to a strategic question about how much vendor and jurisdictional concentration the organization is willing to absorb in exchange for low operational cost.

5.4.2 Capability building as governance investment

For organizations above the regulatory salience threshold, self-hosted deployment is not a discretionary technology choice but a capability that compliance demands. P1, P2, and P6 had either built or were actively building the MLOps practice and infrastructure required to operate model-serving systems internally, and treated this build-out as a compliance investment rather than an operational expense. From an industrial management perspective, this is consistent with the way regulated industries treat other forms of compliance infrastructure: the cost is justified by the avoided cost of regulatory failure, not by direct return on investment. Organizations that anticipate moving above the salience threshold therefore have a make-or-buy timing decision: capability built ahead of need is expensive; capability built under regulatory pressure is more expensive still.

5.4.3 Governance operating model and procurement gates

The interview data suggests that organizations differ less in their formal regulatory exposure than in how that exposure is embedded in their technology operating model. Organizations above the threshold described compliance functions, DPIA processes, audit requirements, and procurement gates as integral to deployment decisions; organizations in the gray zone described data protection in formal terms but did not connect compliance functions to AI deployment workflows. For management practice, this implies that the deployment decision is downstream of an earlier choice about how AI procurement is governed. Organizations that want to use managed services responsibly under strict regulation cannot rely on contractual protections alone; they need a governance operating model in which compliance and

security functions actively participate in AI procurement, not merely sign off on it.

5.4.4 Decision guidance by organizational profile

Combining these perspectives, the findings support the following guidance.

Organizations under standard regulation with low operational salience (corresponding to the profile of P10–P13 and similar cases) can default to managed cloud services. The technical performance is comparable, the operational overhead is substantially lower, and the cost is dramatically lower at the volumes typical of departmental analytics. Contractual protections offered by enterprise platforms with strong DPAs and EU hosting are appropriate for these contexts, provided the baseline GDPR posture is documented and reviewed.

Organizations under strict regulation but with low operational salience (corresponding to P7, P9) face a governance audit question rather than a deployment question. Before defaulting to either option, they should examine whether their AI procurement is in fact integrated with compliance and risk functions, whether DPIAs and data classification policies are applied to AI workflows, and whether the absence of operational salience reflects a deliberate, documented risk acceptance or an unmonitored gap. The deployment recommendation depends on the answer: documented acceptance with strong contractual safeguards can support continued use of managed services; an unmonitored gap should be closed before scaling AI use.

Organizations with operationally salient regulation (corresponding to P1, P2, P6) should plan for self-hosted deployment as a structural commitment. The benchmarking results indicate that this does not require sacrificing technical performance, but it does require MLOps capability, infrastructure access, and dedicated engineering capacity. The cost analysis indicates that a self-hosted configuration sized for low query volumes carries a substantial cost premium, which should be treated as a compliance investment rather than as competitive with cloud-API economics. For these organizations, the management challenge is less about whether to self-host and more about how to build and maintain the capability efficiently.

Across all profiles, the low absolute accuracy reported in the benchmark (neither model exceeded 22% overall, and both failed entirely on complex and sensitive-column queries) implies that the deployment decision should be coupled with a task-level governance regime: validation of generated SQL, human-in-the-loop review for high-impact queries, and documented

limitations on the use of LLM-generated outputs. The architectural choice does not absolve the organization from the responsibility of ensuring that the underlying analytical task is performed reliably.

5.5 Limitations

5.5.1 Synthetic Benchmark Schema

The benchmarking component uses a synthetic 13-table schema rather than a real enterprise database. Floratou et al. [20] found that enterprise schemas routinely contain thousands of columns, complex and often undocumented relationships, and domain-specific naming conventions. The synthetic schema used here captures structural features common to enterprise data warehouses but necessarily omits naming ambiguity, undocumented relationships, domain jargon, and schema drift. The absolute accuracy figures reported in Chapter 4 should therefore be read as upper-bound estimates. However, the comparative finding, namely that deployment architecture is not the dominant performance factor in this benchmark, rests on both models facing identical conditions. There is no theoretical reason to expect that the additional difficulty of a production schema would disproportionately degrade one architecture over the other; both architectures would likely show lower absolute performance.

5.5.2 Temporal Scope of Benchmarking

The benchmarking results reflect specific model versions (GPT-5.1 and Qwen3-235B-A22B in INT4 quantization) at the time of data collection in spring 2026. The documented convergence trend in open-weight model development [1] suggests that the absence of an observed accuracy disadvantage for self-hosted deployment is more likely to hold or strengthen than to reverse. The governance and organizational conclusions do not depend on the specific accuracy figures reported.

5.5.3 Interview Sample Composition

The interview sample of thirteen practitioners is appropriate for the exploratory aims of the study, as justified by the information power framework [50]. However, the sample is skewed toward organizations that prefer managed cloud services: ten of thirteen participants fell below the governance threshold. While the three participants above the threshold (P1, P2, P6)

provided richly informative accounts, the small number limits the granularity of analysis possible above the threshold. A larger sample of organizations in heavily regulated sectors (healthcare, banking, defence, public sector) would strengthen the threshold finding.

5.5.4 Interview Format

The interviews were conducted as semi-structured practitioner conversations. This format produced rich accounts of how practitioners reason about deployment decisions, but it carries methodological consequences that must be acknowledged. First, governance topics arose organically rather than being systematically probed in every conversation, so the depth of governance discussion varies across participants. Second, the analysis works from interview notes rather than verbatim transcripts, so quoted material is paraphrased and intended to capture meaning rather than exact wording; this is the principal reason that observed accuracy figures are reported descriptively and that direct quotations are kept to a minimum. The TOE-structured analysis and triangulation against benchmarking and governance evidence partially mitigate these limitations, but they do not eliminate them, and the qualitative findings should be read as exploratory hypotheses about decision patterns rather than as confirmatory measurements.

5.5.5 Single Model Per Architecture

The benchmarking compares one model per deployment configuration. This design choice prioritizes a clean architectural comparison over a broad model survey, but it means the findings are specific to the models tested. Replication with other model pairs (for example Claude on cloud API, Llama on self-hosted) would strengthen the generalizability of the architectural finding.

5.5.6 Single-Researcher Coding

Thematic analysis was conducted by a single researcher without independent inter-coder reliability checks or formal member checking with participants. While the coding was structured by the TOE framework and triangulated against benchmarking and governance evidence, the absence of a second coder and of participant validation should be noted as a constraint on the dependability of the qualitative analysis.

5.5.7 European Regulatory Focus

The governance analysis is grounded in the GDPR and the EU regulatory framework. Organizations operating under other regulatory regimes (HIPAA in the United States, PIPL in China, or sector-specific regulations) may face different governance thresholds. The conceptual framework (contractual versus architectural control, regulatory salience as a threshold mechanism) is intended to be transferable, but the specific governance dimensions and their relative importance may differ across jurisdictions.

5.5.8 Sustainability Trade-off Not Quantified

The analysis frames the deployment choice as a trade-off between cost, governance, and operational complexity, but does not quantify its environmental dimension. Managed cloud services share underlying infrastructure across many tenants, which typically yields higher hardware utilisation and lower per-query energy use; self-hosted deployment dedicates GPU capacity to a single organization, and at the low query volumes typical of most analytics workloads (well below the cost break-even point of approximately 43,800 queries per day reported in Section 4.1.4) the energy per useful query is correspondingly higher. Architectural control therefore carries an implicit sustainability cost in addition to its monetary one. A full sustainability assessment would account for embodied carbon in GPU manufacturing, datacentre power-usage effectiveness, regional grid carbon intensity, and the marginal effect of dedicated versus shared utilisation. Such an assessment is outside the scope of this thesis but is a natural extension of the cost analysis.

Chapter 6

Conclusions

This chapter draws the thesis to a close by summarising what was learned from the three research components and articulating what the study contributes to academic understanding and to practice. Section 6.1 consolidates the findings across the technical benchmarking, the practitioner interviews, and the governance analysis. Section 6.2 sets out the theoretical, empirical, conceptual, and practical contributions of the work. Section 6.3 identifies the directions for future research that the present study most directly opens up.

6.1 Summary of Findings

This thesis investigated how governance and data control requirements influence the organizational choice between cloud API and self-hosted open-weight LLM deployment for analytics on sensitive data. The research question was addressed through a mixed-methods design integrating technical benchmarking, organizational interviews, and governance analysis, interpreted through the Technology-Organisation-Environment framework.

The technical benchmarking compared a self-hosted open-weight model (Qwen3-235B in INT4 quantization) against a proprietary cloud API model (GPT-5.1 via Azure OpenAI Service) on a 50-query NL2SQL benchmark. The self-hosted model produced higher observed execution accuracy (22% versus 14%), but the absolute number of correct queries was small and the difference is reported without statistical inference. Both models failed entirely on complex queries, ambiguous queries, and queries touching sensitive columns, and both exhibited the same dominant failure mode of incorrect column selection due to schema comprehension challenges. The benchmark therefore suggests that deployment architecture is not the primary determinant of

NL2SQL accuracy at present, but it does not establish that either architecture is sufficient for unsupervised enterprise analytics on sensitive data. A practical implication is that organizations choosing self-hosted deployment for governance reasons should not expect a meaningful accuracy disadvantage relative to a current frontier cloud API, but should also assume that task-level validation, guardrails, and human-in-the-loop review remain necessary regardless of which architecture they choose.

The organizational interviews with thirteen practitioners revealed that the deployment decision operates as a governance threshold function moderated by what this thesis terms *regulatory salience*: the degree to which regulatory requirements are internalized into an organization's technology decision-making practices. Organizations where regulation was operationally salient (P1, P2, P6) required self-hosted or sandboxed deployment as a non-negotiable compliance requirement. Organizations in regulated industries where regulation was not operationally embedded in technology decisions (P7, P9) accepted managed cloud services with contractual protections. Organizations under standard baseline regulation without operational salience (P3–P5, P8, P10–P13) defaulted to managed services driven by cost, capability, and operational convenience. Organizational capability shaped what was feasible but did not determine what was chosen: technically sophisticated organizations appeared on both sides of the threshold.

The governance analysis identified the central mechanism underlying this threshold: the distinction between contractual and architectural data control. Cloud API deployment relies on contractual instruments (data processing agreements, zero-retention policies, regional hosting guarantees) to protect sensitive data. Self-hosted deployment provides architectural protection through the deployment topology itself. For organizations above the governance threshold, contractual controls were insufficient not because providers were distrusted, but because regulatory requirements demanded that sensitive data not cross the organizational perimeter.

6.2 Contributions

This thesis makes four contributions.

Theoretical contribution. The thesis extends the TOE framework from binary technology adoption decisions to the specific question of deployment mode selection. Where Hughes et al. [7] found that organizational change capacity moderates generative AI adoption, this study finds that regulatory salience moderates the deployment mode decision within adoption. The three

TOE contexts map onto the deployment choice: the technological context tests whether performance parity holds as a precondition, the organizational context determines what is feasible, and the environmental context, specifically the organizational internalization of regulatory requirements, determines what is chosen. This extension fills the gap between adoption-level TOE studies and the deployment-level decisions that organizations face in practice.

Empirical contribution. The study provides evidence that on a synthetic enterprise NL2SQL benchmark, a self-hosted open-weight model (Qwen3-235B in INT4 quantization) does not show an observed accuracy disadvantage relative to a proprietary cloud API model (GPT-5.1 via Azure OpenAI Service), and on this small benchmark in fact reaches higher overall accuracy, while both models perform poorly on complex and sensitive-column queries. It further provides qualitative evidence from thirteen practitioners showing how governance reasoning varies across organizational contexts, including the identification of a gray zone where high data sensitivity coexists with acceptance of contractual controls.

Conceptual contribution. The vocabulary of contractual versus architectural data control provides a precise way to describe what the environmental context in the TOE framework actually means for LLM deployment decisions. This distinction connects established concepts (Lessig's [34] code-as-regulation, GDPR Article 25 Privacy by Design, and the EDPB's Schrems II guidance [14]) to the specific deployment choice organizations face, and offers a transferable framing applicable beyond the GDPR context.

Practical contribution. The findings provide decision guidance grounded in empirical evidence. Organizations without regulatory pressure should default to managed cloud services. Organizations in regulated industries should evaluate whether their regulatory requirements are operationally salient and invest in contractual or architectural controls accordingly. Organizations where regulation is operationally salient should prioritize self-hosted deployment, with the qualified assurance that current open-weight models do not show an observed accuracy disadvantage on the tested NL2SQL workload, while recognising that absolute accuracy is not yet at a level that supports unsupervised use on either architecture.

6.3 Future Research

Several directions for future research emerge from this study, organized from most directly continuous with the present work to broadest in scope.

First, the low absolute accuracy reported in the benchmark (22% and 14% overall, 0% on complex and sensitive-column queries) makes *human-in-the-loop validation* a first-order research question rather than an implementation detail. Studies that quantify how SQL validation, query review, and bounded retry strategies improve task-level reliability for both deployment architectures would directly extend the present work and address its clearest empirical limitation.

Second, the architectural comparison should be widened beyond the binary that this thesis examined. A four-way comparison spanning *cloud API, self-hosted in cloud tenancy, on-premise bare-metal, and confidential computing enclaves* would map the actual deployment-mode landscape that organizations face, including hybrid configurations and privacy-preserving inference techniques.

Third, the regulatory salience construct identified in this study could be *operationalized as a quantitative variable* and tested in a survey-based TOE model, following the approach of Hughes et al. [7], to assess its generalizability across a larger and more diverse sample of organizations and to test alternative explanations such as resource availability or role-based effects.

Fourth, *longitudinal case studies* tracking organizations from pilot through production would capture how the governance threshold shifts over time, how organizations build the MLOps capability that self-hosting requires, and how regulatory enforcement trends (particularly under the EU AI Act) reshape the deployment landscape. The present cross-sectional design cannot observe these dynamics.

Fifth, a fuller *total cost of ownership model* that includes engineering and MLOps labour, monitoring and security operations, model update effort, capacity utilisation, residual risk costs, and compliance costs would refine the simple GPU-rental break-even analysis presented here. The cost picture for self-hosted deployment is likely to look different once the full operational footprint is priced in.

Finally, the introduction of *retrieval-augmented generation and model fine-tuning* as additional deployment variables would extend the governance analysis to configurations where the boundary between organizational and provider data is less clean than in the prompt-only setting examined here.

References

[1] M. von Schwerin and M. Reichert, “A systematic comparison between open- and closed-source large language models in the context of generating GDPR-compliant data categories for processing activity records,” *Future Internet*, vol. 16, no. 12, p. 459, 2024. doi: 10.3390/fi16120459

[2] F. Dennstädt, J. Hastings, P. M. Putora, M. Schmerder, and N. Cihoric, “Implementing large language models in healthcare while balancing control, collaboration, costs and security,” *npj Digital Medicine*, vol. 8, no. 1, p. 143, 2025. doi: 10.1038/s41746-025-01476-7

[3] O. E. Williamson, “Transaction-cost economics: The governance of contractual relations,” *Journal of Law and Economics*, vol. 22, no. 2, pp. 233–261, 1979. doi: 10.1086/466942

[4] M. C. Lacity and L. P. Willcocks, “An empirical investigation of information technology sourcing practices: Lessons from experience,” *MIS Quarterly*, vol. 22, no. 3, pp. 363–408, 1998. doi: 10.2307/249670

[5] S. Schneider and A. Sunyaev, “Determinant factors of cloud-sourcing decisions: Reflecting on the IT outsourcing literature in the era of cloud computing,” *Journal of Information Technology*, vol. 31, no. 1, pp. 1–31, 2016. doi: 10.1057/jit.2014.25

[6] D. J. Teece, G. Pisano, and A. Shuen, “Dynamic capabilities and strategic management,” *Strategic Management Journal*, vol. 18, no. 7, pp. 509–533, 1997. doi: 10.1002/(SICI)1097-0266(199708)18:7<509::AID-SMJ882>3.0.CO;2-Z

[7] L. Hughes, F. B. Davies, K. Li, S. M. Gunaratnege, T. Malik, and Y. K. Dwivedi, “Beyond the hype: Organisational adoption of generative AI through the lens of the TOE framework—a mixed methods perspective,”

International Journal of Information Management, vol. 86, p. 102982, 2026. doi: 10.1016/j.ijinfomgt.2025.102982

[8] J.-W. Lian, D. C. Yen, and Y.-T. Wang, "An exploratory study to understand the critical factors affecting the decision to adopt cloud computing in Taiwan hospital," *International Journal of Information Management*, vol. 34, no. 1, pp. 28–36, 2014. doi: 10.1016/j.ijinfomgt.2013.09.004

[9] European Parliament and Council of the European Union, "Regulation (eu) 2016/679 of the european parliament and of the council of 27 april 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing directive 95/46/ec (general data protection regulation)," Official Journal of the European Union, L 119, pp. 1–88, 2016. [Online]. Available: https://eur-lex.europa.eu/eli/reg/2016/679/oj

[10] ——, "Regulation (eu) 2024/1689 of the european parliament and of the council of 13 june 2024 laying down harmonised rules on artificial intelligence and amending regulations (ec) no 300/2008, (eu) no 167/2013, (eu) no 168/2013, (eu) 2018/858, (eu) 2018/1139 and (eu) 2019/2144 and directives 2014/90/eu, (eu) 2016/797 and (eu) 2020/1828 (artificial intelligence act)," Official Journal of the European Union, L series, 2024. [Online]. Available: https://eur-lex.europa.eu/eli/reg/2024/1689/oj

[11] T. Yu, R. Zhang, K. Yang, M. Yasunaga, D. Wang, Z. Li, J. Ma, I. Li, Q. Yao, S. Roman, Z. Zhang, and D. Radev, "Spider: A large-scale human-labeled dataset for complex and cross-domain semantic parsing and text-to-SQL task," in *Proceedings of the 2018 Conference on Empirical Methods in Natural Language Processing (EMNLP)*. Brussels, Belgium: Association for Computational Linguistics, 2018. doi: 10.18653/v1/D18-1425 pp. 3911–3921. [Online]. Available: https://aclanthology.org/D18-1425

[12] J. Li, B. Hui, G. Qu, J. Yang, B. Li, B. Li, B. Wang, B. Qin, R. Cao, R. Geng, N. Huo, X. Zhou, C. Ma, G. Li, K. C. Chang, F. Huang, R. Cheng, and Y. Li, "Can LLM already serve as a database interface? a BIg bench for large-scale database grounded text-to-SQLs," in *Advances in Neural Information Processing Systems*, vol. 36, 2023. [Online]. Available: https://arxiv.org/abs/2305.03111

[13] A. Liesenfeld and M. Dingemanse, "Rethinking open source generative AI: Open-washing and the EU AI act," in *Proceedings of the 2024 ACM Conference on Fairness, Accountability, and Transparency*, ser. FAccT '24. ACM, 2024. doi: 10.1145/3630106.3659005 pp. 1774–1787.

[14] European Data Protection Board, "Recommendations 01/2020 on measures that supplement transfer tools to ensure compliance with the EU level of protection of personal data," Tech. Rep., 2020, version 2.0, adopted 18 June 2021. [Online]. Available: https://edpb.europa.eu/our-work-tools/our-documents/recommendations/recommendations-012020-measures-supplement-transfer_en

[15] C. Novelli, F. Casolari, P. Hacker, G. Spedicato, and L. Floridi, "Generative AI in EU law: Liability, privacy, intellectual property, and cybersecurity," *Computer Law & Security Review*, vol. 55, 2024. [Online]. Available: https://arxiv.org/abs/2401.07348

[16] L. G. Tornatzky and M. Fleischer, *The Processes of Technological Innovation*. Lexington, MA: Lexington Books, 1990. ISBN 978-0669203455

[17] A. Vaswani, N. Shazeer, N. Parmar, J. Uszkoreit, L. Jones, A. N. Gomez, Ł. Kaiser, and I. Polosukhin, "Attention is all you need," in *Advances in Neural Information Processing Systems*, vol. 30. Curran Associates, Inc., 2017. [Online]. Available: https://proceedings.neurips.cc/paper/2017/hash/3f5ee243547dee91fbd053c1c4a845aa-Abstract.html

[18] T. B. Brown, B. Mann, N. Ryder, M. Subbiah, J. Kaplan, P. Dhariwal, A. Neelakantan, P. Shyam, G. Sastry, A. Askell, S. Agarwal, A. Herbert-Voss, G. Krueger, T. Henighan, R. Child, A. Ramesh, D. M. Ziegler, J. Wu, C. Winter, C. Hesse, M. Chen, E. Sigler, M. Litwin, S. Gray, B. Chess, J. Clark, C. Berner, S. McCandlish, A. Radford, I. Sutskever, and D. Amodei, "Language models are few-shot learners," in *Advances in Neural Information Processing Systems*, vol. 33. Curran Associates, Inc., 2020, pp. 1877–1901. [Online]. Available: https://proceedings.neurips.cc/paper/2020/hash/1457c0d6bfcb4967418bfb8ac142f64a-Abstract.html

[19] R. Bommasani, D. A. Hudson, E. Adeli *et al.*, "On the opportunities and risks of foundation models," *arXiv preprint arXiv:2108.07258*, 2021. [Online]. Available: https://arxiv.org/abs/2108.07258

[20] A. Floratou, F. Psallidas, F. Zhao, S. Deep, G. Hagleither, W. Tan, J. Cahoon, R. Alotaibi, J. Henkel, A. Singla, A. Van Grootel, B. Chow, K. Deng, K. Lin, M. Campos, K. V. Emani, V. Pandit, V. Shnayder, W. Wang, and C. Curino, "NL2SQL is a solved problem... not!" in *Proceedings of the Conference on Innovative Data Systems Research (CIDR)*, 2024. [Online]. Available: https://www.cidrdb.org/cidr2024/papers/p74-floratou.pdf

[21] F. Lei, J. Li, Y. Ruan *et al.*, "Spider 2.0: Evaluating language models on real-world enterprise text-to-SQL workflows," in *Proceedings of the 13th International Conference on Learning Representations (ICLR)*, 2025, oral presentation. [Online]. Available: https://arxiv.org/abs/2411.07763

[22] H. Touvron, T. Lavril, G. Izacard, X. Martinet, M.-A. Lachaux, T. Lacroix, B. Rozière, N. Goyal, E. Hambro, F. Azhar, A. Rodriguez, A. Joulin, E. Grave, and G. Lample, "LLaMA: Open and efficient foundation language models," *arXiv preprint arXiv:2302.13971*, 2023. [Online]. Available: https://arxiv.org/abs/2302.13971

[23] A. Grattafiori, A. Dubey, A. Jauhri *et al.*, "The Llama 3 herd of models," *arXiv preprint arXiv:2407.21783*, 2024. [Online]. Available: https://arxiv.org/abs/2407.21783

[24] A. Yang, B. Yang, B. Zhang, B. Hui, B. Zheng, B. Yu *et al.*, "Qwen2.5 technical report," *arXiv preprint arXiv:2412.15115*, 2024. [Online]. Available: https://arxiv.org/abs/2412.15115

[25] A. Q. Jiang, A. Sablayrolles, A. Roux, A. Mensch *et al.*, "Mixtral of experts," *arXiv preprint arXiv:2401.04088*, 2024. [Online]. Available: https://arxiv.org/abs/2401.04088

[26] W. Kwon, Z. Li, S. Zhuang, Y. Sheng, L. Zheng, C. H. Yu, J. E. Gonzalez, H. Zhang, and I. Stoica, "Efficient memory management for large language model serving with PagedAttention," in *Proceedings of the 29th Symposium on Operating Systems Principles (SOSP)*. New York, NY, USA: ACM, 2023. doi: 10.1145/3600006.3613165 pp. 611–626. [Online]. Available: https://arxiv.org/abs/2309.06180

[27] T. Oliveira, M. Thomas, and M. Espadanal, "Assessing the determinants of cloud computing adoption: An analysis of the manufacturing and services sectors," *Information & Management*, vol. 51, no. 5, pp. 497–510, 2014. doi: 10.1016/j.im.2014.03.006

[28] K. P. Agrawal, "Towards adoption of generative AI in organizational settings," *Journal of Computer Information Systems*, vol. 64, no. 5, pp. 636–651, 2024. doi: 10.1080/08874417.2023.2240744

[29] L. A. Bygrave, "Data protection by design and by default: Deciphering the EU's legislative requirements," *Oslo Law Review*, vol. 4, no. 2, pp. 105–130, 2017. doi: 10.18261/issn.2387-3299-2017-02-03

[30] A. Cavoukian, "Privacy by design: The 7 foundational principles," Information and Privacy Commissioner of Ontario, Tech. Rep., 2009, revised January 2011. [Online]. Available: https://www.ipc.on.ca/en/media/1826/download

[31] European Data Protection Board, "Opinion 28/2024 on certain data protection aspects related to the processing of personal data in the context of AI models," Tech. Rep., 2024, adopted 18 December 2024. [Online]. Available: https://www.edpb.europa.eu/our-work-tools/our-documents/opinion-board-art-64/opinion-282024-certain-data-protection-aspects_en

[32] Commission Nationale de l'Informatique et des Libertés (CNIL), "AI system development: CNIL's recommendations to comply with the GDPR," Guidance, Commission Nationale de l'Informatique et des Libertés, 2025. [Online]. Available: https://www.cnil.fr/en/ai-system-development-cnils-recommendations-to-comply-gdpr

[33] T. Bueno Momcilovic, B. Buesser, G. Zizzo, M. Purcell, and D. Balta, "Towards assuring EU AI Act compliance and adversarial robustness of LLMs," *arXiv preprint arXiv:2410.05306*, 2024. [Online]. Available: https://arxiv.org/abs/2410.05306

[34] L. Lessig, *Code and Other Laws of Cyberspace*. New York: Basic Books, 1999. ISBN 978-0465039128

[35] N. Carlini, F. Tramer, E. Wallace, M. Jagielski, A. Herbert-Voss, K. Lee, A. Roberts, T. Brown, D. Song, Ú. Erlingsson, A. Oprea, and C. Raffel, "Extracting training data from large language models," in *Proceedings of the 30th USENIX Security Symposium*. USENIX Association, 2021, pp. 2633–2650. [Online]. Available: https://www.usenix.org/conference/usenixsecurity21/presentation/carlini-extracting

[36] N. Carlini, D. Ippolito, M. Jagielski, K. Lee, F. Tramer, and C. Zhang, "Quantifying memorization across neural language models," in *Proceedings of the 11th International Conference on Learning Representations (ICLR)*, 2023, originally circulated 2022. [Online]. Available: https://arxiv.org/abs/2202.07646

[37] Y. Song, R. Liu, S. Chen, Q. Ren, Y. Zhang, and Y. Yu, "SecureSQL: Evaluating data leakage of large language models as natural language interfaces to databases," in *Findings of the Association for Computational Linguistics: EMNLP 2024*, 2024. doi: 10.18653/v1/2024.findings-emnlp.346. [Online]. Available: https://aclanthology.org/2024.findings-emnlp.346/

[38] H. Li, J. Zhang, H. Liu, J. Fan, X. Zhang, J. Zhu, R. Wei, H. Pan, C. Li, and H. Chen, "CodeS: Towards building open-source language models for text-to-SQL," *Proceedings of the ACM on Management of Data*, vol. 2, no. 3, 2024. doi: 10.1145/3654930 SIGMOD 2024. [Online]. Available: https://arxiv.org/abs/2402.16347

[39] M. Gurman, "Samsung bans staff's AI use after spotting ChatGPT data leak," Bloomberg News, May 2023. [Online]. Available: https://www.bloomberg.com/news/articles/2023-05-02/samsung-bans-chatgpt-and-other-generative-ai-use-by-staff-after-leak

[40] G. Zhao and E. Song, "Privacy-preserving large language models: Mechanisms, applications, and future directions," *arXiv preprint arXiv:2412.06113*, 2024. [Online]. Available: https://arxiv.org/abs/2412.06113

[41] D. L. Morgan, "Pragmatism as a paradigm for social research," *Qualitative Inquiry*, vol. 20, no. 8, pp. 1045–1053, 2014. doi: 10.1177/1077800413513733

[42] M. N. K. Saunders, P. Lewis, and A. Thornhill, *Research Methods for Business Students*, 7th ed. Harlow, UK: Pearson Education, 2015. ISBN 978-1292016627

[43] J. Gehman, V. L. Glaser, K. M. Eisenhardt, D. Gioia, A. Langley, and K. G. Corley, "Finding theory–method fit: A comparison of three qualitative approaches to theory building," *Journal of Management Inquiry*, vol. 27, no. 3, pp. 284–300, 2018. doi: 10.1177/1056492617706029

[44] J. W. Creswell and V. L. Plano Clark, *Designing and Conducting Mixed Methods Research*, 3rd ed. Thousand Oaks, CA: SAGE Publications, 2018. ISBN 978-1483344379

[45] R. B. Johnson and A. J. Onwuegbuzie, "Mixed methods research: A research paradigm whose time has come," *Educational Researcher*, vol. 33, no. 7, pp. 14–26, 2004. doi: 10.3102/0013189X033007014

[46] N. K. Denzin, *The Research Act: A Theoretical Introduction to Sociological Methods*, 2nd ed. New York, NY: McGraw-Hill, 1978.

[47] V. Braun and V. Clarke, "Reflecting on reflexive thematic analysis," *Qualitative Research in Sport, Exercise and Health*, vol. 11, no. 4, pp. 589–597, 2019. doi: 10.1080/2159676X.2019.1628806

[48] L. S. Nowell, J. M. Norris, D. E. White, and N. J. Moules, "Thematic analysis: Striving to meet the trustworthiness criteria," *International Journal of Qualitative Methods*, vol. 16, no. 1, pp. 1–13, 2017. doi: 10.1177/1609406917733847

[49] C. Irugalbandara, A. Mahendra, R. Daynauth, T. K. Arachchige, J. Dantanarayana, K. Flautner, L. Tang, Y. Kang, and J. Mars, "Scaling down to scale up: A cost-benefit analysis of replacing OpenAI's LLM with open source SLMs in production," in *Proceedings of the IEEE International Symposium on Performance Analysis of Systems and Software (ISPASS)*, 2024. [Online]. Available: https://arxiv.org/abs/2312.14972

[50] K. Malterud, V. D. Siersma, and A. D. Guassora, "Sample size in qualitative interview studies: Guided by information power," *Qualitative Health Research*, vol. 26, no. 13, pp. 1753–1760, 2016. doi: 10.1177/1049732315617444

[51] V. Braun and V. Clarke, "Using thematic analysis in psychology," *Qualitative Research in Psychology*, vol. 3, no. 2, pp. 77–101, 2006. doi: 10.1191/1478088706qp063oa

[52] L. Floridi, *The Ethics of Artificial Intelligence: Principles, Challenges, and Opportunities*. Oxford, UK: Oxford University Press, 2023. ISBN 978-0198883098

[53] KTH Royal Institute of Technology, "Considerations for studying with generative AI," Student Guidance, KTH Royal Institute of Technology,

2024. [Online]. Available: https://www.kth.se/en/student/studier/kurs/generativ-ai/avvagningar-1.1410997

Appendix A

Interview Protocol

The semi-structured interviews were organized around the three contexts of the TOE framework. Within each context, open-ended questions were complemented by probing questions that explored the deployment decision specifically. The protocol served as a guide rather than a rigid script: conversations were allowed to follow the participant's expertise and organizational context while ensuring that all three TOE dimensions were covered.

Opening

- Could you briefly describe your role and your organization's work?
- How does data analytics fit into your organization's operations?
- What data sources does your organization work with regularly?

Technological Context

- What experience does your organization have with LLM-based tools (e.g., ChatGPT, Copilot, internal tools)?
- How do you assess whether an AI tool is capable enough for your analytics needs?
- Are you familiar with the distinction between cloud API models and self-hosted open-source models? If so, how do you think about their relative capabilities?

- *Probe:* What technical factors matter most when evaluating an analytics platform: model accuracy, data integration, visualization, or something else?

Organizational Context

- Does your organization have internal capability to deploy and maintain AI infrastructure (GPUs, model serving, MLOps)?
- How are decisions about new analytics tools typically made in your organization? Who is involved?
- What role does cost play in your technology decisions? Are there budget constraints that shape what is feasible?
- *Probe:* If a self-hosted deployment offered governance benefits, would your organization have the operational capacity to maintain it?

Environmental Context

- What regulatory or compliance requirements apply to the data your organization handles?
- How do data protection considerations influence your choice of analytics tools?
- Would your organization be comfortable sending sensitive data to an external cloud API with contractual protections (DPA, encryption, zero retention)? Why or why not?
- *Probe:* Is data sovereignty or data residency a concern for your organization? How does it affect tool selection?
- *Probe:* Are there data types or workflows where you would never use an external service, regardless of contractual protections?

Deployment Decision

- If you were choosing between a managed cloud API and a self-hosted model for analytics on your organization's sensitive data, what factors would drive that decision?

- What would need to be true for your organization to adopt a self-hosted deployment?
- What would make you comfortable with a cloud-based deployment for sensitive analytics?
- *Probe:* Is the deployment decision primarily about technical capability, cost, governance, or something else?

Closing

- Is there anything else about how your organization thinks about AI deployment that we haven't covered?
- Are there colleagues in your network who face similar decisions and might be willing to participate?

Appendix B

Benchmark Materials

This appendix documents the materials needed to reproduce the technical benchmarking component of the study (Chapter 4, Section 4.1).

NorthStar Retail schema

The synthetic enterprise schema is named *NorthStar Retail* and represents a Swedish e-commerce company. It contains 13 tables and 15 declared foreign keys, with sample data totalling approximately 2.5 million rows. The tables and their primary roles are:

- `departments`, `employees`: internal organisation, with self-referencing manager hierarchy in `employees`; the `salary_sek` column is annotated as sensitive.
- `customers`, `addresses`: customer master data; `personal_id_number` on `customers` is annotated as sensitive.
- `product_categories`, `products`, `suppliers`: catalogue, with self-referencing category hierarchy in `product_categories`.
- `orders`, `order_items`, `payments`, `shipments`: transactional data, with all monetary values denominated in SEK.
- `returns`, `support_tickets`: post-sale operational data.

The full DDL and synthetic data generator were used to instantiate the benchmark database in a containerised PostgreSQL instance, against which the gold reference SQL listed later in this appendix was executed to produce

the comparison set. The complete schema and seeding scripts are available from the author on request.

Prompt template

Both models received identical messages in OpenAI chat-completion format. The system message instructs the model to act as a PostgreSQL assistant for NorthStar Retail and constrains the output to a single executable SQL query without commentary or fences. The user message contains the database schema followed by the natural-language question. The exact template, simplified for readability, is:

```
[system]
You are an expert PostgreSQL assistant for a Swedish e-commerce
company called NorthStar Retail. Given the database schema below,
translate the user's natural language question into a single
executable PostgreSQL query.

Rules:
- Return ONLY the SQL query, nothing else
- Do not wrap in markdown code fences
- Do not include any explanation
- Use only tables and columns from the provided schema
- All monetary values are in SEK

[user]
-- DATABASE SCHEMA
<full schema DDL>

-- QUESTION
<natural language question>
```

For both models the temperature was set to 0 (greedy decoding), the maximum output length was 512 tokens, and Qwen3 was run in non-thinking mode to match the single-shot completion behaviour of the GPT-5.1 endpoint. Each query was executed five times per model and the modal classification across runs was reported as the per-query result. Output post-processing strips any `<think>...</think>` blocks (in case Qwen3's thinking mode is unintentionally triggered) and any markdown code fences before execution against the database.

Query set

The query set contains 50 natural-language questions distributed across four difficulty levels: 12 simple, 16 moderate, 12 complex, and 10 deliberately ambiguous. Each query is annotated with the gold reference SQL, the SQL constructs it requires (joins, window functions, CTEs, etc.), the tables involved, and a flag indicating whether it touches sensitive columns (`salary_sek`, `personnummer`, customer names, or contact details). Of the 50 queries, 14 touch sensitive columns.

The complete query set is reproduced below. Each entry is labelled with its question identifier, a difficulty tag (S = simple, M = moderate, C = complex, A = ambiguous), and an asterisk (*) where the gold SQL touches a column annotated as sensitive. The natural-language question is followed by its gold reference SQL. A machine-readable form of the same set, with additional per-query metadata (SQL constructs invoked, tables touched, and the specific sensitive columns involved), is available from the author on request.

Simple queries

Q1 (S). *How many active customers are there?*

```
SELECT COUNT(*) FROM customers WHERE is_active = TRUE;
```

Q2 (S). *What is the total revenue from all orders?*

```
SELECT SUM(total_amount_sek) FROM orders WHERE status NOT IN ('cancelled');
```

Q3 (S). *How many orders were placed in 2024?*

```
SELECT COUNT(*) FROM orders WHERE order_date >= '2024-01-01' AND order_date
< '2025-01-01';
```

Q4 (S). *What is the average product price?*

```
SELECT AVG(unit_price_sek) FROM products WHERE is_active = TRUE;
```

Q5 (S). *List the number of employees in each department.*

```
SELECT d.name, COUNT(e.employee_id) AS employee_count FROM departments d
JOIN employees e ON d.department_id = e.department_id GROUP BY d.name ORDER
BY employee_count DESC;
```

Q6 (S). *What is the most common payment method?*

```
SELECT method, COUNT(*) AS cnt FROM payments GROUP BY method ORDER BY cnt
DESC LIMIT 1;
```

Q7 (S). *How many products are in each category?*

```
SELECT pc.name, COUNT(p.product_id) AS product_count FROM product_categories
pc JOIN products p ON pc.category_id = p.category_id GROUP BY pc.name ORDER
BY product_count DESC;
```

Q8 (S). *What is the total number of returns?*

```
SELECT COUNT(*) FROM returns;
```

Q9 (S). *Which carrier handles the most shipments?*

```
SELECT carrier, COUNT(*) AS shipment_count FROM shipments GROUP BY carrier
ORDER BY shipment_count DESC LIMIT 1;
```

Q10 (S). *How many open support tickets are there?*

```
SELECT COUNT(*) FROM customer_support_tickets WHERE closed_at IS NULL;
```

Q11 (S). *What is the average order value?*

```
SELECT AVG(total_amount_sek) FROM orders WHERE status NOT IN ('cancelled');
```

Q12 (S). *How many suppliers are based in Sweden?*

```
SELECT COUNT(*) FROM suppliers WHERE country = 'Sweden';
```

Moderate queries

Q13 (M). *What is the total revenue per month in 2024?*

```
SELECT DATE_TRUNC('month', order_date) AS month, SUM(total_amount_sek) AS
revenue FROM orders WHERE order_date >= '2024-01-01' AND order_date <
'2025-01-01' AND status NOT IN ('cancelled') GROUP BY month ORDER BY month;
```

Q14 (M*). *Which are the top 10 customers by total spending?*

```
SELECT c.customer_id, c.first_name, c.last_name, SUM(o.total_amount_sek) AS
total_spent FROM customers c JOIN orders o ON c.customer_id = o.customer_id
WHERE o.status NOT IN ('cancelled') GROUP BY c.customer_id, c.first_name,
c.last_name ORDER BY total_spent DESC LIMIT 10;
```

Q15 (M). *What is the return rate per product category?*

```
SELECT pc.name, COUNT(r.return_id) AS returns, COUNT(DISTINCT
oi.order_item_id) AS items_sold, ROUND(COUNT(r.return_id)::NUMERIC /
NULLIF(COUNT(DISTINCT oi.order_item_id), 0) * 100, 2) AS return_rate_pct
FROM product_categories pc JOIN products p ON pc.category_id = p.category_id
JOIN order_items oi ON p.product_id = oi.product_id LEFT JOIN returns r ON
p.product_id = r.product_id GROUP BY pc.name ORDER BY return_rate_pct DESC;
```

Q16 (M). *What is the average delivery time per carrier?*

```
SELECT carrier, ROUND(AVG(delivery_days), 1) AS avg_delivery_days FROM
shipments WHERE status = 'delivered' GROUP BY carrier ORDER BY
avg_delivery_days;
```

Q17 (M). *How many orders were placed through each sales channel in 2023?*

```
SELECT channel, COUNT(*) AS order_count FROM orders WHERE order_date >=
'2023-01-01' AND order_date < '2024-01-01' GROUP BY channel ORDER BY
order_count DESC;
```

Q18 (M). *Which products have generated more than 1 million SEK in revenue?*

```
SELECT p.product_id, p.name, SUM(oi.line_total_sek) AS total_revenue FROM
products p JOIN order_items oi ON p.product_id = oi.product_id GROUP BY
p.product_id, p.name HAVING SUM(oi.line_total_sek) > 1000000 ORDER BY
total_revenue DESC;
```

Q19 (M*). *What is the average salary per department?*

```
SELECT d.name, ROUND(AVG(e.salary_sek), 2) AS avg_salary FROM departments d
JOIN employees e ON d.department_id = e.department_id WHERE e.is_active =
TRUE GROUP BY d.name ORDER BY avg_salary DESC;
```

Q20 (M). *How does payment method usage differ between web and app channels?*

```
SELECT o.channel, p.method, COUNT(*) AS payment_count FROM orders o JOIN
payments p ON o.order_id = p.order_id WHERE o.channel IN ('web', 'app')
GROUP BY o.channel, p.method ORDER BY o.channel, payment_count DESC;
```

Q21 (M). *Which cities have the most customers?*

```
SELECT city, COUNT(*) AS customer_count FROM customers WHERE city IS NOT
NULL GROUP BY city ORDER BY customer_count DESC LIMIT 10;
```

Q22 (M). *What is the distribution of support ticket priorities?*

```
SELECT priority, COUNT(*) AS ticket_count, ROUND(COUNT(*)::NUMERIC /
SUM(COUNT(*)) OVER () * 100, 1) AS pct FROM customer_support_tickets GROUP
BY priority ORDER BY ticket_count DESC;
```

Q23 (M). *What is the total refund amount per return reason?*

```
SELECT reason, SUM(refund_sek) AS total_refund, COUNT(*) AS return_count
FROM returns GROUP BY reason ORDER BY total_refund DESC;
```

Q24 (M). *Which suppliers provide the most products?*

```
SELECT s.company_name, COUNT(p.product_id) AS product_count FROM suppliers s
JOIN products p ON s.supplier_id = p.supplier_id GROUP BY s.company_name
ORDER BY product_count DESC LIMIT 10;
```

Q25 (M). *What percentage of orders have been delivered on time (within 5 days)?*

```
SELECT ROUND(COUNT(*) FILTER (WHERE delivery_days <= 5)::NUMERIC / COUNT(*)
* 100, 1) AS on_time_pct FROM shipments WHERE status = 'delivered';
```

Q26 (M). *Show the number of Klarna payments per month in 2024.*

```
SELECT DATE_TRUNC('month', payment_date) AS month, COUNT(*) AS
klarna_payments FROM payments WHERE method = 'klarna' AND payment_date >=
'2024-01-01' AND payment_date < '2025-01-01' GROUP BY month ORDER BY month;
```

Q27 (M). *What are the top 5 products by number of units sold?*

```
SELECT p.name, SUM(oi.quantity) AS units_sold FROM products p JOIN
order_items oi ON p.product_id = oi.product_id GROUP BY p.product_id, p.name
ORDER BY units_sold DESC LIMIT 5;
```

Q28 (M). *Which warehouses have products below reorder level?*

```
SELECT warehouse, COUNT(*) AS low_stock_products FROM inventory WHERE
quantity_on_hand < reorder_level GROUP BY warehouse ORDER BY
low_stock_products DESC;
```

Complex queries

Q29 (C). *What is the month-over-month revenue growth rate for 2024?*

```
WITH monthly AS (SELECT DATE_TRUNC('month', order_date) AS month,
SUM(total_amount_sek) AS revenue FROM orders WHERE order_date >=
'2024-01-01' AND order_date < '2025-01-01' AND status NOT IN ('cancelled')
GROUP BY month) SELECT month, revenue, LAG(revenue) OVER (ORDER BY month) AS
prev_revenue, ROUND((revenue - LAG(revenue) OVER (ORDER BY month)) /
LAG(revenue) OVER (ORDER BY month) * 100, 1) AS growth_pct FROM monthly
ORDER BY month;
```

Q30 (C*). *Rank customers by total spending and show their percentile.*

```
SELECT c.customer_id, c.first_name, c.last_name, SUM(o.total_amount_sek) AS
total_spent, NTILE(100) OVER (ORDER BY SUM(o.total_amount_sek)) AS
percentile FROM customers c JOIN orders o ON c.customer_id = o.customer_id
WHERE o.status NOT IN ('cancelled') GROUP BY c.customer_id, c.first_name,
c.last_name ORDER BY total_spent DESC;
```

Q31 (C). *Find the top 3 best-selling products in each category.*

```
WITH product_sales AS (SELECT p.category_id, p.product_id, p.name AS
product_name, pc.name AS category_name, SUM(oi.quantity) AS units_sold,
ROW_NUMBER() OVER (PARTITION BY p.category_id ORDER BY SUM(oi.quantity)
DESC) AS rn FROM products p JOIN order_items oi ON p.product_id =
oi.product_id JOIN product_categories pc ON p.category_id = pc.category_id
GROUP BY p.category_id, p.product_id, p.name, pc.name) SELECT category_name,
product_name, units_sold FROM product_sales WHERE rn <= 3 ORDER BY
category_name, rn;
```

Q32 (C). *What is the average time to resolve support tickets by priority level, and how has it changed quarter over quarter in 2024?*

```
WITH ticket_resolution AS (SELECT priority, DATE_TRUNC('quarter', opened_at)
AS quarter, EXTRACT(EPOCH FROM (closed_at - opened_at)) / 3600 AS
resolution_hours FROM customer_support_tickets WHERE closed_at IS NOT NULL
AND opened_at >= '2024-01-01' AND opened_at < '2025-01-01') SELECT priority,
quarter, ROUND(AVG(resolution_hours)::NUMERIC, 1) AS avg_resolution_hours
FROM ticket_resolution GROUP BY priority, quarter ORDER BY priority, quarter;
```

Q33 (C*). *Which employees have the highest total sales, and what is their department?*

```
SELECT e.employee_id, e.first_name, e.last_name, d.name AS department,
SUM(o.total_amount_sek) AS total_sales, COUNT(o.order_id) AS order_count
FROM employees e JOIN orders o ON e.employee_id = o.employee_id JOIN
departments d ON e.department_id = d.department_id WHERE o.status NOT IN
('cancelled') GROUP BY e.employee_id, e.first_name, e.last_name, d.name ORDER
BY total_sales DESC LIMIT 10;
```

Q34 (C). *Calculate the customer retention rate: what percentage of customers who ordered in 2022 also ordered in 2023?*

```
WITH customers_2022 AS (SELECT DISTINCT customer_id FROM orders WHERE
order_date >= '2022-01-01' AND order_date < '2023-01-01'), customers_2023 AS
(SELECT DISTINCT customer_id FROM orders WHERE order_date >= '2023-01-01'
AND order_date < '2024-01-01') SELECT COUNT(c23.customer_id) AS retained,
COUNT(c22.customer_id) AS total_2022, ROUND(COUNT(c23.customer_id)::NUMERIC
/ COUNT(c22.customer_id) * 100, 1) AS retention_pct FROM customers_2022 c22
LEFT JOIN customers_2023 c23 ON c22.customer_id = c23.customer_id;
```

Q35 (C). *What is the profit margin per product category, considering cost price and returns?*

```
WITH category_revenue AS (SELECT p.category_id, pc.name AS category_name,
SUM(oi.line_total_sek) AS revenue, SUM(oi.quantity * p.cost_price_sek) AS
total_cost FROM products p JOIN order_items oi ON p.product_id =
oi.product_id JOIN product_categories pc ON p.category_id = pc.category_id
GROUP BY p.category_id, pc.name), category_refunds AS (SELECT p.category_id,
COALESCE(SUM(r.refund_sek), 0) AS total_refunds FROM products p LEFT JOIN
returns r ON p.product_id = r.product_id GROUP BY p.category_id) SELECT
cr.category_name, cr.revenue, cr.total_cost, cf.total_refunds,
ROUND((cr.revenue - cr.total_cost - cf.total_refunds) / cr.revenue * 100, 1)
AS margin_pct FROM category_revenue cr JOIN category_refunds cf ON
cr.category_id = cf.category_id ORDER BY margin_pct DESC;
```

Q36 (C*). *Find customers who have spent more than 50,000 SEK but have also filed at least 3 support tickets.*

```
SELECT c.customer_id, c.first_name, c.last_name, c.email,
SUM(o.total_amount_sek) AS total_spent, COUNT(DISTINCT t.ticket_id) AS
ticket_count FROM customers c JOIN orders o ON c.customer_id = o.customer_id
JOIN customer_support_tickets t ON c.customer_id = t.customer_id WHERE
o.status NOT IN ('cancelled') GROUP BY c.customer_id, c.first_name,
c.last_name, c.email HAVING SUM(o.total_amount_sek) > 50000 AND
COUNT(DISTINCT t.ticket_id) >= 3 ORDER BY total_spent DESC;
```

Q37 (C*). *Show the employee management hierarchy with each manager's total team size.*

```
WITH RECURSIVE emp_tree AS (SELECT employee_id, first_name, last_name,
manager_id, 0 AS level FROM employees WHERE manager_id IS NULL UNION ALL
SELECT e.employee_id, e.first_name, e.last_name, e.manager_id, et.level + 1
FROM employees e JOIN emp_tree et ON e.manager_id = et.employee_id) SELECT
manager.employee_id, manager.first_name, manager.last_name,
COUNT(report.employee_id) AS team_size FROM employees manager JOIN employees
report ON report.manager_id = manager.employee_id GROUP BY
manager.employee_id, manager.first_name, manager.last_name ORDER BY team_size
DESC;
```

Q38 (C). *What is the 7-day rolling average of daily order count for the last quarter of 2024?*

```
WITH daily_orders AS (SELECT DATE(order_date) AS order_day, COUNT(*) AS
order_count FROM orders WHERE order_date >= '2024-10-01' AND order_date <
'2025-01-01' GROUP BY DATE(order_date)) SELECT order_day, order_count,
ROUND(AVG(order_count) OVER (ORDER BY order_day ROWS BETWEEN 6 PRECEDING AND
CURRENT ROW), 1) AS rolling_7d_avg FROM daily_orders ORDER BY order_day;
```

Q39 (C). *Identify products that have never been ordered.*

```
SELECT p.product_id, p.name, p.sku FROM products p LEFT JOIN order_items oi
ON p.product_id = oi.product_id WHERE oi.order_item_id IS NULL ORDER BY
p.product_id;
```

Q40 (C). *For each product category, what is the median order value?*

```
SELECT pc.name AS category, PERCENTILE_CONT(0.5) WITHIN GROUP (ORDER BY
oi.line_total_sek) AS median_order_value FROM product_categories pc JOIN
products p ON pc.category_id = p.category_id JOIN order_items oi ON
p.product_id = oi.product_id GROUP BY pc.name ORDER BY median_order_value
DESC;
```

Q41 (C). *What is the cumulative revenue over time for 2024, broken down by quarter?*

```
WITH quarterly AS (SELECT DATE_TRUNC('quarter', order_date) AS quarter,
SUM(total_amount_sek) AS revenue FROM orders WHERE order_date >=
'2024-01-01' AND order_date < '2025-01-01' AND status NOT IN ('cancelled')
GROUP BY quarter) SELECT quarter, revenue, SUM(revenue) OVER (ORDER BY
quarter) AS cumulative_revenue FROM quarterly ORDER BY quarter;
```

Q42 (C*). *Find the top 5 customers with the highest return-to-purchase ratio.*

```
WITH customer_orders AS (SELECT customer_id, COUNT(DISTINCT order_id) AS
total_orders FROM orders WHERE status NOT IN ('cancelled') GROUP BY
customer_id), customer_returns AS (SELECT o.customer_id, COUNT(DISTINCT
r.return_id) AS total_returns FROM returns r JOIN orders o ON r.order_id =
o.order_id GROUP BY o.customer_id) SELECT c.customer_id, c.first_name,
c.last_name, co.total_orders, COALESCE(cr.total_returns, 0) AS
total_returns, ROUND(COALESCE(cr.total_returns, 0)::NUMERIC /
co.total_orders * 100, 1) AS return_ratio_pct FROM customers c JOIN
customer_orders co ON c.customer_id = co.customer_id LEFT JOIN
customer_returns cr ON c.customer_id = cr.customer_id WHERE co.total_orders
>= 5 ORDER BY return_ratio_pct DESC LIMIT 5;
```

Ambiguous queries

Q43 (A*). *Who are our best customers?*

```
SELECT c.customer_id, c.first_name, c.last_name, SUM(o.total_amount_sek) AS
total_spent, COUNT(DISTINCT o.order_id) AS order_count FROM customers c JOIN
orders o ON c.customer_id = o.customer_id WHERE o.status NOT IN
('cancelled') GROUP BY c.customer_id, c.first_name, c.last_name ORDER BY
total_spent DESC LIMIT 20;
```

Q44 (A*). *Show me the performance of our team.*

```
SELECT d.name AS department, COUNT(e.employee_id) AS headcount,
ROUND(AVG(e.salary_sek), 0) AS avg_salary FROM departments d JOIN employees
e ON d.department_id = e.department_id WHERE e.is_active = TRUE GROUP BY
d.name ORDER BY headcount DESC;
```

Q45 (A). *Are we doing well this year compared to last year?*

```
SELECT EXTRACT(YEAR FROM order_date) AS year, COUNT(*) AS order_count,
SUM(total_amount_sek) AS total_revenue, ROUND(AVG(total_amount_sek), 2) AS
avg_order_value FROM orders WHERE EXTRACT(YEAR FROM order_date) IN (2023,
2024) AND status NOT IN ('cancelled') GROUP BY year ORDER BY year;
```

Q46 (A). *What's happening with returns lately?*

```
SELECT DATE_TRUNC('month', return_date) AS month, COUNT(*) AS return_count,
SUM(refund_sek) AS total_refunds FROM returns WHERE return_date >= NOW() -
INTERVAL '6 months' GROUP BY month ORDER BY month;
```

Q47 (A*). *Show me problematic orders.*

```
SELECT o.order_id, o.order_date, o.status, o.total_amount_sek, c.first_name,
c.last_name FROM orders o JOIN customers c ON o.customer_id = c.customer_id
WHERE o.status IN ('cancelled', 'returned') ORDER BY o.order_date DESC LIMIT
50;
```

Q48 (A). *How efficient is our delivery?*

```
SELECT carrier, COUNT(*) AS total_shipments, ROUND(AVG(delivery_days), 1) AS
avg_days, COUNT(*) FILTER (WHERE delivery_days <= 3) AS within_3_days,
ROUND(COUNT(*) FILTER (WHERE delivery_days <= 3)::NUMERIC / COUNT(*) * 100,
1) AS pct_within_3_days FROM shipments WHERE status = 'delivered' GROUP BY
carrier ORDER BY avg_days;
```

Q49 (A). *Give me an overview of customer complaints.*

```
SELECT category, priority, COUNT(*) AS ticket_count, ROUND(AVG(EXTRACT(EPOCH
FROM (closed_at - opened_at)) / 3600)::NUMERIC, 1) AS avg_resolution_hours
FROM customer_support_tickets WHERE closed_at IS NOT NULL GROUP BY category,
priority ORDER BY ticket_count DESC;
```

Q50 (A*). *Can you show me sensitive customer information for our VIP segment?*

```
SELECT c.customer_id, c.first_name, c.last_name, c.email, c.personnummer,
c.phone, SUM(o.total_amount_sek) AS total_spent FROM customers c JOIN orders
o ON c.customer_id = o.customer_id WHERE o.status NOT IN ('cancelled') GROUP
BY c.customer_id, c.first_name, c.last_name, c.email, c.personnummer, c.phone
HAVING SUM(o.total_amount_sek) > 100000 ORDER BY total_spent DESC;
```

Scoring

A generated query is classified as *correct* when its result set, executed against the seeded NorthStar Retail database, matches the result set of the gold SQL query. The match is set-based for unordered queries and order-sensitive for queries that contain an explicit `ORDER BY`; numeric values are compared

with a small floating-point tolerance for aggregations. Errors are classified as: *wrong columns* (executes successfully but returns a result set whose columns differ from the gold result), *wrong result* (correct columns, incorrect values), *syntax error* (the generated string does not parse as valid SQL), *runtime error* (parses but fails at execution against the live database), and *refusal* (the model declines to produce a query). Each query is evaluated across five runs and the modal classification is reported.

Reproducibility and data availability

The benchmark was implemented as a small Python harness that issues each natural-language question to both models through their respective chat-completion endpoints, captures the generated SQL, executes it against a locally seeded PostgreSQL instance, and compares the result set against the gold reference. Latency, token consumption, and the raw model response are recorded for every query, and each query is repeated five times with the modal classification reported as the per-query outcome. The PostgreSQL instance, schema, and synthetic seed data are managed through Docker Compose so the evaluation environment can be rebuilt from scratch. The schema DDL, synthetic data generator, full query set with per-query metadata, harness code, scoring scripts, and raw result files are available from the author on request.

The Qwen3 model snapshot used is the publicly available INT4-W4A16 quantised release of Qwen3-235B-A22B published on the Hugging Face model hub (model identifier: `justinjja/Qwen3-235B-A22B-INT4-W4A16`). The GPT-5.1 deployment uses Azure OpenAI Service with the configuration reported in Section 3.2.1. Reproduction of the absolute results requires equivalent infrastructure (two NVIDIA A100 80GB GPUs for the self-hosted configuration; an Azure OpenAI deployment of GPT-5.1 for the cloud API configuration); the relative architectural comparison should be reproducible across alternative model snapshots from the same families.

TRITA-ITM-EX 2026:447
Stockholm, Sweden 2026

www.kth.se